ACTIVE DIRECTORY SECURITY ASSESSMENT

essos.local *Security* Report

End-to-end analysis of attack paths, privilege escalations, and compliance gaps identified during the engagement.

REPORT DATE	October 09, 2026
REPORT TYPE	Active Directory Security Assessment
PROFILE	Full
DOMAINS	1 assessed

DOC · ESSOS.LOCAL · ADSCAN

OVERALL POSTURE **CRITICAL**

9	6	4	17
CRITICAL	HIGH	MEDIUM	ATTACK PATHS

EXECUTIVE SUMMARY · READ IN 30 SECONDS

Your AD posture is critical. 14 paths to full domain compromise require immediate executive attention.

EXPOSURE TO DOMAIN COMPROMISE

How much of the worst-case exposure to full domain compromise this environment carries. The account figure below is measured separately.

100% of the maximum exposure score

14 ATTACK PATHS TO FULL DOMAIN COMPROMISE

1 OF THE 14 VALIDATED END-TO-END
10 OF THE 14 PARTIALLY VALIDATED
3 OF THE 14 IDENTIFIED BY CONFIGURATION ANALYSIS

0% 25% 50% 75% 100%

6 of 6 ordinary (non-administrative) domain users **have a path to full domain compromise, confirmed by configuration**

100% OF YOUR NON-ADMINISTRATIVE ACCOUNTS · 1 OF THESE ATTACK PATHS WAS EXECUTED END TO END DURING THE ASSESSMENT, THE REMAINING ROUTES MAPPED FROM CONFIGURATION

A FURTHER **3** OF THE 9 ACCOUNTS ASSESSED (33%) ALREADY HOLD TIER 0 PRIVILEGE BY GROUP MEMBERSHIP AND ARE EXCLUDED FROM THE FIGURE ABOVE.

9 domain users hold a path confirmed by configuration in total: 6 ordinary (non-administrative) + 3 already-privileged (Tier 0, the compromise target itself).

MOST EXPOSED ACCOUNTS · WHICH ACCOUNTS THE MOST COMPROMISE PATHS CAN REACH

There is no low-risk ordinary account here: all 6 ordinary users share the same exposure. Each one reaches the same 17 compromise routes, 1 of them validated end to end. Harden the shared chain the whole population funnels through, not any single account.

Because every ordinary account is equally exposed, the fix is not a per-account control list: break the shared chain the whole population funnels through (see the prioritised remediation below), enforce administrative tiering, and deploy LAPS on the hosts these accounts can reach.

MOST PROVEN FIX · VALIDATED IN THIS ENVIRONMENT

Certificate Template Privilege Escalation (ADCS ESC1)

1 of 1 path

Top fix breaks validated attack paths ADscan executed

Executed end to end, closed by one fix

WIDEST SURFACE CUT · MOST PATHS CLOSED

Pre-Authentication-less Credential Theft (ASREPRoasting)

9

of 17 mapped attack paths closed in one change

The largest single surface reduction in this environment.

COMPROMISE REACH · THE TIER EACH ATTACK PATH CAN TAKE OVER

14
FULL DOMAIN COMPROMISE
Attack paths proving total control of the domain.

0
TIER 0 FOOTHOLD
Access to a Tier 0 host. Post-exploitation required.

0
TIER 0 GROUP TAKEOVER
Escalates toward, but does not yet prove, domain takeover.

0
STEPPING-STONE TO TIER 0
Advances toward Tier 0 without landing on it.

BASELINE SEVERITY DISTRIBUTION

22 findings



Critical 9 High 6 Medium 4 Low 3

BOTTOM LINE

Score sits in the critical band (8/100), driven by 14 paths to full domain compromise, which demand immediate executive attention regardless of severity counts. Cut every path by closing the underlying findings that drive them: 9 critical and 6 high. Start with the ranked remediation priorities in section 07. Each fix breaks multiple paths at once.

For trend tracking only: posture score 8/100 on the inverse scale, higher is safer.

00

DOCUMENT MAP

Contents

Executive findings, technical evidence, compliance mapping, and the prioritised remediation roadmap for this engagement.

01 **Executive Summary**

1.1 Overall Risk Posture

1.2 Priority Findings

1.3 Compliance Snapshot

· How We Tier Privilege & Reach

02 **Attack Path Analysis**

03 **Technical Findings**

04 **MITRE ATT&CK Coverage**

05 **NIS2 Compliance Mapping**

06 **DORA Compliance Mapping**

07 **Start Here - Fixes That Break the Most Attack Paths**

08 **Remediation Roadmap**

09 **Environment Modifications & Cleanup**

01 Executive Summary

High-level assessment overview for senior leadership.

OVERALL RISK POSTURE

Critical risk: immediate executive attention required

9	6	4	3	17
CRITICAL	HIGH	MEDIUM	LOW	ATTACK PATHS

***14** of 17 reach full domain compromise*

1 exploited

10 partially validated

3 theoretical

1 not assessed

2 hardening observed

SEVERITY DISTRIBUTION



Critical (9) High (6) Medium (4) Low (3)

An automated Active Directory security assessment was conducted across 1 Active Directory domain. A total of 22 security findings were detected. **15 high-priority findings (9 critical, 6 high)** were identified that represent an immediate threat to business operations and regulatory standing.

During the assessment, **1 attack path** to full domain compromise was validated end-to-end by executing every step against the live environment. This confirms that a threat actor with standard internal network access could achieve complete control over the Active Directory environment without requiring advanced capabilities. Of the remaining attack paths to full domain compromise, **10** were **partially validated**: at least one step of each chain executed successfully against the live environment, though the chains were not run end-to-end. The other **3** were identified through configuration analysis and not executed. Immediate containment action is required.

The highest-priority issues requiring management attention are *ADCS ESC1 - Misconfigured Certificate Template*, *AS-REP Roasting*, and *ADCS ESC5 - Vulnerable CA Object ACL*. Full technical detail and step-by-step remediation guidance are provided in the Technical Findings section of this report.

The identified gaps have direct implications for compliance with NIS2 Directive and DORA (Digital Operational Resilience Act). Regulatory frameworks in scope require effective identity and access controls. The Active Directory weaknesses documented here represent evidence of control failure that auditors and regulators would classify as significant non-conformities.

Immediate executive escalation is required. The security team should initiate emergency remediation within **30 days**. Board-level oversight of the remediation programme is recommended.

Assessment scope: Every figure in this report is derived from 1 enumerated Active Directory domain: essos.local.

Engagement integrity: ADscan made 2 changes to Active Directory during this assessment to demonstrate exploitability.

Action required: 2 changes could not be reverted automatically and require manual cleanup. See section 09 (Environment Modifications & Cleanup) for the exact objects and remediation commands.

Compliance Snapshot

At-a-glance regulatory posture across assessed frameworks. Full control-level detail in dedicated sections.

NIS2 AT RISK

0%

ASSESSED CONTROLS CONFORMANT

4 major non-conformities require action

DORA AT RISK

0%

ASSESSED CONTROLS CONFORMANT

7 major non-conformities require action

Priority Findings

The findings that lead remediation for this directory, in the same order as Section 07 (Start Here), which ranks fixes by how many attack paths each one breaks. The ADscan Priority score on each card is that finding's severity for tracking, not the ordering, so the scores are not monotonic. Full details in Technical Findings.

PRIORITY 9.9

ADCS ESC1 - Misconfigured Certificate Template

ADCS ESC1 occurs when a certificate template is configured to allow requesters to specify a Subject Alternative Name (SAN) in their certificate request, combined with an...

ADSCAN ANALYSIS

ESC1 abuse confirmed: certificate enrollment with attacker-supplied SAN succeeded

Domain: `essos.local` CWE: `CWE-269`

PRIORITY 6.9

AS-REP Roasting

Preauthentication offers protection against offline Password Cracking. When enabled, a user requesting access to a resource initiates communication with the Domain Controller...

Domain: `essos.local` CWE: `CWE-522`

PRIORITY 9.0

ADCS ESC5 - Vulnerable CA Object ACL

ADCS ESC5 involves misconfigured access controls on CA-level objects in Active Directory beyond certificate templates, including the CA server computer object, the CA object in...

ADSCAN ANALYSIS

ESC5 PKI ACL exposure affects Tier-0 trust

Domain: `essos.local` CWE: `CWE-269`

T0

How We Tier Privilege & Reach

Two distinct questions answered with one vocabulary: the Tier a principal or asset holds, and the Tier it can take over through a path confirmed by configuration.

AXIS 1 · PRIVILEGE TIER

What an account or asset is granted

A static property from group membership, following the Microsoft Tiered Administration Model. Tier 0 is a containment boundary: any Tier 0 principal, if compromised, can take over the forest.

AXIS 2 · COMPROMISE REACH

What it can take over via a path confirmed by configuration

The effective result we demonstrate from the attack graph, expressed as the highest Tier a principal can reach. The gap between a low Tier held and a high Tier reached is the headline risk.

Tier 0: Domain Control

Identity control plane. Compromise is immediate, one-step ownership of the domain.

MEMBERS Domain Admins, Enterprise Admins, BUILTIN\Administrators, Domain Controllers, Schema Admins, krbtgt, the built-in Administrator (RID 500); Domain Controller computers.

Tier 0: Escalation-capable

Inside the Tier 0 boundary: not immediate domain ownership, but owns the forest through one known escalation technique (e.g. Backup Operators reading NTDS.dit).

MEMBERS Backup Operators, Account Operators, Server Operators, Print Operators, DnsAdmins, Cert Publishers, Key Admins, Group Policy Creator Owners, the read-only Domain Controller groups, and the Exchange privileged groups; the Certification Authority and certificate templates.

BASIS Most groups in this tier have a concrete single-step escalation to domain control. A small set (Cryptographic Operators, Distributed COM Users, Performance Log Users) is included for industry-tooling parity: they are flagged conservatively as Tier 0 even though no single-step domain-compromise technique is known for them today.

Tier 1: Server / Application Admin

Server and application plane. Controls business workloads and their data, but not the identity control plane.

MEMBERS Member servers (SQL, Exchange, SharePoint, line-of-business application servers) and the accounts that administer them.

BASIS Tier 1 is inferred, not read from a fixed attribute: a machine is graded Tier 1 from its server role (operating system and published service names such as SQL or Exchange), and an account is graded Tier 1 when it holds full administrative control over a Tier 1 server. A server where ordinary users log on interactively (a Remote Desktop or Citrix host) is treated as Tier 2, and a server that administers a Domain Controller or other Tier 0 asset is treated as Tier 0. These inferences are conservative and customer-overridable.

Tier 2: Standard

Standard user plane. No granted privilege over servers or the domain by membership alone. This is where an intrusion begins and what ADscan measures reach from.

MEMBERS Standard user accounts and workstations.

CONFIDENCE OF EACH TIER

Tier 0 is determined deterministically from control-plane group membership and Domain Controller role, so it is a high-confidence classification. Tier 1 is inferred from server role and administrative control, because Active Directory has no fixed attribute for it; every Tier 1 verdict is a conservative inference and is customer-overridable.

HOW ADSCAN MAPS TO MICROSOFT'S TIER MODEL

ADscan applies Microsoft's AD DS tier model. Tier 0 (the identity control plane) and Tier 1 (server and application administration) follow Microsoft's definitions directly. For Tier 2, ADscan uses the attack-path convention (every standard user account), because that is where an intrusion begins and what ADscan measures reach FROM. Microsoft's tier model is an administration framework; ADscan is an exposure framework, so the two describe the same boundary from different sides.

ENTERPRISE ACCESS MODEL MAPPING

For teams that use Microsoft's newer Enterprise Access Model, the tiers map as follows: Tier 0 corresponds to the Control plane, Tier 1 to the Management and Data/Workload plane, and Tier 2 to User and Application access. Tier 0/1/2 remains the primary label throughout this report.

COMPROMISE REACH · THE FOUR CLASSES

FULL DOMAIN COMPROMISE

Path to full domain compromise, confirmed by configuration (control of a Tier 0 asset)

The path's final step takes control of a Tier 0 asset (a Domain Admin, a Domain Controller, or the domain object itself), so the domain is fully compromised.

TIER 0 FOOTHOLD

Foothold on a Tier 0 asset (control pending validation)

The path's final step lands an interactive session on a Tier 0 machine (for example remote access to a Domain Controller). Full control of that machine is the next step and is pending validation.

TIER 0 GROUP TAKEOVER

Control of a Tier 0 escalation group (one technique from domain)

The path's final step takes control of a Tier 0 escalation group (such as Backup Operators or DnsAdmins). Membership in that group reaches the domain through one further known technique.

STEPPING-STONE TO TIER 0

Path that advances toward Tier 0, confirmed by configuration

The path's final step lands on a waypoint below Tier 0 that meaningfully advances toward domain compromise without yet reaching a Tier 0 asset.

READING THE COMPROMISE REACH VIEW

Throughout this report, the **Tier 0 Exposure** rollup counts the accounts and assets with a path to a Tier 0 target, confirmed by configuration. A *Path to full domain compromise, confirmed by configuration (control of a Tier 0 asset)* proves total control of the domain; *Foothold on a Tier 0 asset (control pending validation)* means the attack path lands on a Tier 0 host where takeover is the next step but not yet proven. Prioritisation follows how **direct** the path is: a path to Domain Admin outranks a path to an escalation-capable group, even though both targets sit inside the Tier 0 boundary.

02 Attack Path Analysis

End-to-end attack chains identified in the Active Directory environment.

Attack path classification. EXPLOITED Successfully validated end-to-end during active testing. PARTIALLY VALIDATED A segment of the chain was executed successfully (at least one step proven), but it was not run end-to-end: the exploitation is proven, the initial access unconfirmed. Stronger than Attempted. NOT EXECUTED FOR SAFETY The route is real and the preconditions were confirmed. ADscan stopped short of the step that would disrupt production, so the exposure stands and only the disruptive act was declined. ATTEMPTED Probed but not fully completed. THEORETICAL Mapped from configuration analysis; not actively exploited. NOT ASSESSED No reachable surface for ADscan to test this avenue during the engagement, so its exposure is unknown rather than mapped. HARDENING OBSERVED Your own configuration closes this avenue, observed directly. A positive finding, not exposure.

How these counts reconcile. The chips beside each domain below cover every card in that domain and add up to its total. The status says how far execution got; TO FULL DOMAIN COMPROMISE says how many of those attack paths END in control of the domain: that is the count page 2 leads with (14). The remaining EXPLOITED, PARTIALLY VALIDATED, NOT EXECUTED FOR SAFETY, ATTEMPTED and THEORETICAL cards stop at a Tier 0 foothold or an escalation group and are counted separately on page 2. NOT ASSESSED and HARDENING OBSERVED cards are shown for completeness and carry no exposure, so they sit outside every one of those figures.

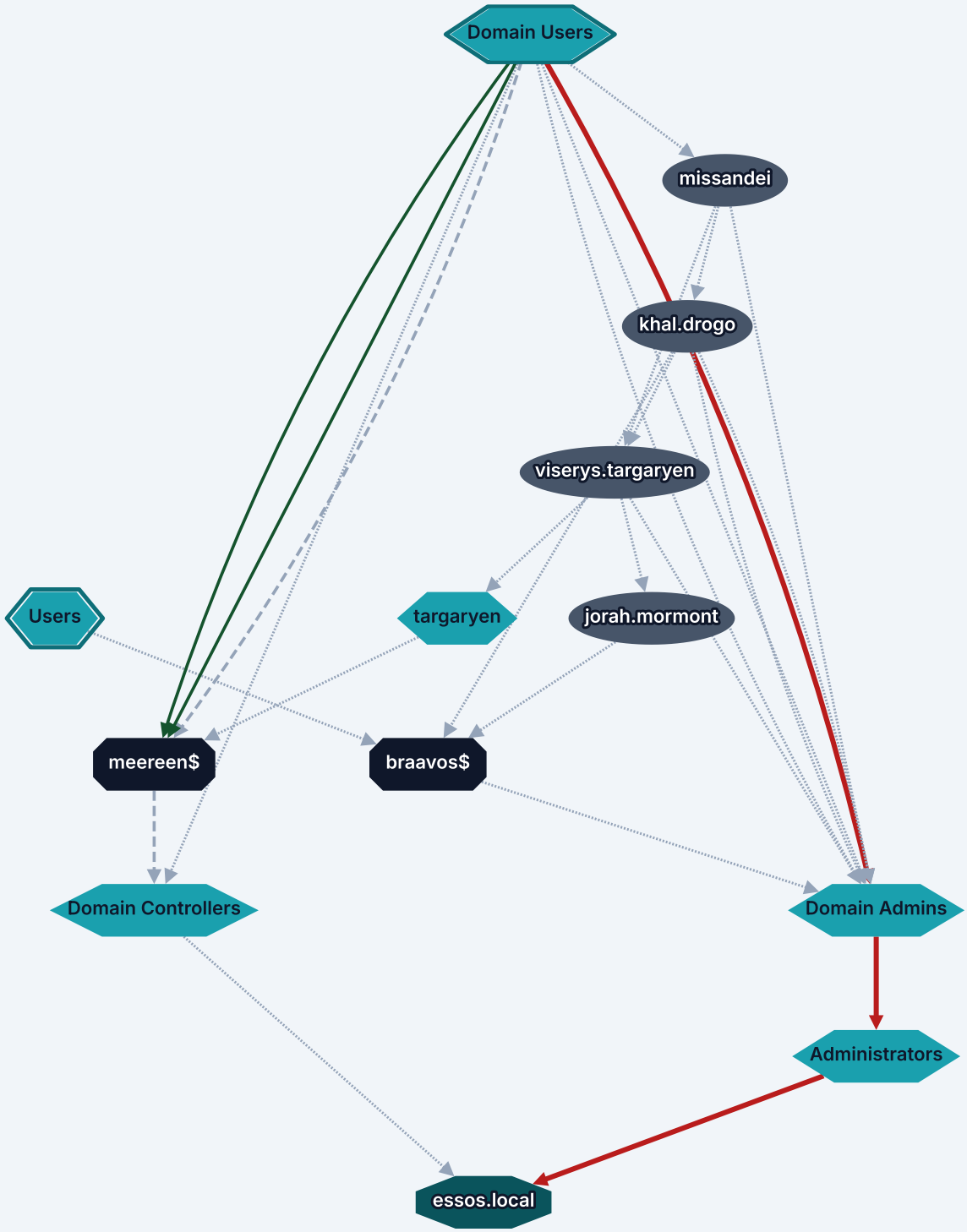
essos.local

1 EXPLOITED · 10 PARTIALLY VALIDATED · 3 THEORETICAL · 1 NOT ASSESSED · 2 HARDENING OBSERVED · 17 PATHS · 14 OF 17 REACH FULL DOMAIN COMPROMISE

ROUTE COVERAGE

ADscan evaluated 18 candidate routes, which deduplicated into 17 attack paths. ADscan walked 1 of them fully to domain compromise and proved the entry step on 10 more.

Attack surface map · essos.local · all 17 attack paths, collapsed onto shared nodes



Every attack path at a glance. Each is drawn on its own on the pages that follow, where its steps and targets are named.

HOW TO READ THIS MAP

User account · Group: privilege held by membership · Computer or machine account · Domain · Ringed: where the route starts

Validated: executed end to end · Not assessed · Identified by configuration analysis · Closed by configuration already in place

TECHNIQUES BEHIND THESE ATTACK PATHS

The attack paths below are built from 9 recurring techniques. Each is explained here once, worked through on the first place it appears, together with the change that closes it wherever it appears. Every attack path then names its own principals and targets step by step and refers back here for the mechanism. The list is ordered by how many steps depend on each technique, so fixing the one at the top removes the most attack paths.

GROUP MEMBERSHIP (MEMBEROF) 18 STEPS

Domain Admins is a direct or nested member of Administrators. All privileges held by Administrators, including any onward attack-path edges, are inherited by Domain Admins.

REPLICATE DIRECTORY SECRETS (DCSYNC) 17 STEPS

Administrators holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

> **REMEDIATION**
>
> - Revoke the replication rights held by <TRUSTEE>. That account is the finding: it can request a full replica of every password hash and Kerberos key in the domain, and nothing about its role requires that.
> - Audit who holds the replication extended rights on the domain head with (Get-Acl 'AD:<DOMAIN-DN>').Access, then remove the grant with dsacls "<DOMAIN-DN>" /R "DOMAIN\<TRUSTEE>".
> - Replication itself is not the finding. Your domain controllers hold these rights because replication is how the directory works, and a confirmed Azure AD Connect account holds them to support Password Hash Sync; both are reported separately as Tier 0 assets to protect. The holder named above is in neither group.
> - Enable audit logging for directory service replication events (Event ID 4662) and alert on replication requests from non-DC hosts
> - Rotate the KRBTGT password twice to invalidate any Golden Tickets that may have been issued before remediation

PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) 9 STEPS

ASREPRoasting targets accounts, in this path missandei, that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including Domain Users) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for missandei.

> **REMEDIATION**
>
> - Enable Kerberos pre-authentication for missandei (clear DONT_REQ_PREAUTH in userAccountControl).
> - Enforce strong passwords on accounts that must keep pre-auth disabled.
> - Monitor Event ID 4768 with pre-authentication type 0 for anomalous requests.

FULL CONTROL OF THE TARGET OBJECT (GENERICALL) 7 STEPS

GenericAll grants user missandei full read and write control over user khal.drogo. The source can reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink) to obtain a PKINIT certificate, or set a servicePrincipalName to make the account kerberoastable, any of which leads to full compromise of khal.drogo.

> **REMEDIATION**
>
> - Audit the change: Event ID 5136 records the modified access control list on the object, and Event ID 4662 records the object access itself. Both require DS Access auditing to be enabled on the container.

MODIFY THE TARGET OBJECT (GENERICWRITE) 5 STEPS

GenericWrite gives user missandei the ability to modify most attributes of user viserys.targaryen. The source can reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink) to obtain a PKINIT certificate, or set a servicePrincipalName to make the account kerberoastable, any of which leads to full compromise of viserys.targaryen.

> **REMEDIATION**
>
> - Sweep for the same exposure elsewhere: `Get-ADObject -LDAPFilter '(msDS-KeyCredentialLink=*)' -Properties msDS-KeyCredentialLink | Select-Object DistinguishedName` lists every object carrying a key credential, which on a domain that does not use Windows Hello for Business should be close to empty.
> - Audit the change: Event ID 5136 records the modified access control list and any subsequent write to msDS-KeyCredentialLink or servicePrincipalName on the object. It requires DS Access auditing to be enabled on the container.

CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) 4 STEPS

ADCS ESC5 covers write-level control (GenericAll, GenericWrite, WriteDacl, WriteOwner, or Owns) over the high-value PKI objects that underpin certificate trust: the NTAuthStore (which lists the CAs trusted for domain client authentication), the Root CA and AIA CA objects, and the Enterprise CA object itself. computer braavos$ with such a right on Domain Admins can, for example, publish an attacker-controlled CA into NTAuth so that certificates it issues are trusted for logon, or otherwise reconfigure the CA to mint authentication certificates for privileged identities. Because these objects govern the whole PKI trust chain, compromising one is equivalent to controlling certificate-based authentication across the domain.

REMEDIATION

- Restrict the ACL on the affected PKI object (Domain Admins) so only Tier-0 PKI administrators hold write access; use dsacls / Set-Acl to revoke GenericAll / GenericWrite / WriteDacl / WriteOwner from every other principal.
- Review the NTAuth store with certutil -viewstore -enterprise NTAuth and remove any CA certificate that should not be trusted for domain authentication.
- Set the owner of each PKI container (NTAuthStore, Root CA, AIA, Enterprise CA) to a Tier-0 group and treat these objects as part of the identity control plane.
- Enable auditing on the PKI containers so any future change to their ACL or contents is logged and alerted on.

CERTIFICATE MAPPING ABUSE (ADCS ESC9) 3 STEPS

ADCS ESC9 abuses a certificate template whose msPKI-Enrollment-Flag includes CT_FLAG_NO_SECURITY_EXTENSION, which tells the CA NOT to embed the szOID_NTDS_CA_SECURITY_EXT SID security extension in the issued certificate. Without that extension the domain controller falls back to weak, name-based certificate-to-account mapping. user missandei, holding enrollment rights on the client authentication template ESC9 with no manager approval, can (typically after altering a controllable account's UPN, or combined with a shadow-credential / password-reset primitive) enroll a certificate that a DC then maps to a privileged victim, authenticating as them and compromising Domain Admins.

REMEDIATION

- Clear the CT_FLAG_NO_SECURITY_EXTENSION flag on ESC9 so issued certificates carry the szOID_NTDS_CA_SECURITY_EXT SID extension and bind strongly to the enrolling account.
- Set StrongCertificateBindingEnforcement to 2 (Full enforcement) on domain controllers per KB5014754 so a certificate without the SID extension is rejected for authentication.
- Restrict enrollment on ESC9 and remove it from broad groups so a low-privileged principal cannot request it.
- Protect the write paths that let an attacker change a victim's UPN or add a key credential (the pairing ESC9 depends on) by auditing GenericWrite / GenericAll on user objects.

READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) 2 STEPS

The ReadLAPSPassword edge means jorah.mormont has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of braavos$. jorah.mormont simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to braavos$.

REMEDIATION

- Remove the Control Access ACE on ms-Mcs-AdmPwd / ms-LAPS-Password from jorah.mormont on braavos$.
- Audit LDAP reads of ms-LAPS-Password via Event ID 4662 with the LAPS GUID.

REMOTE DESKTOP ACCESS (CANRDP) 2 STEPS

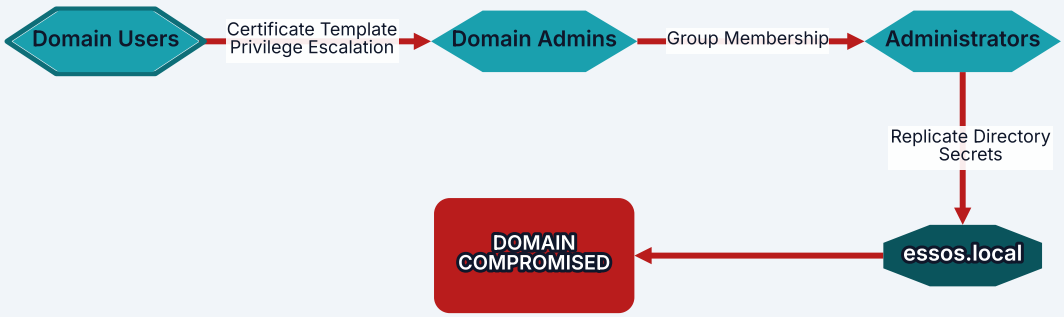
Membership in the Remote Desktop Users group (or local administrator rights) lets group Targaryen establish an interactive RDP session on meereen$. An interactive logon is more powerful than a network logon: the account gets a full desktop, its credentials are cached in LSASS for the life of the session, and any other user already logged on interactively has their tokens and cached secrets exposed to anyone who reaches SYSTEM on that box. RDP is a sanctioned administration channel, so the traffic itself blends in: the risk is who can reach it and what privilege they land with. If Restricted Admin mode is not enforced, the interactive credentials are recoverable, making a single RDP foothold a pivot for credential theft and onward lateral movement.

REMEDIATION

- Review the Remote Desktop Users group on the host and remove principals that do not need interactive access: Invoke-Command -ComputerName meereen.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Remote Desktop Users' }.
- Require Network Level Authentication and, for administrative RDP, enable Restricted Admin mode (Set-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Lsa' -Name DisableRestrictedAdmin -Value 0) so credentials are not left recoverable in the session.
- Restrict which source hosts may reach TCP 3389 with a host firewall / network segmentation rule so RDP is not exposed broadly across the estate.
- Add high-value accounts to the Protected Users group and enforce tier separation so Tier-0 credentials never RDP into member servers. Monitor Event IDs 4624 (logon type 10) and 4778 for interactive RDP sessions.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE EXPLOITED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Certificate Template Privilege Escalation, Group Membership, and Replicate Directory Secrets. This attack path was successfully exploited during active testing.



Group: privilege held by membership · Domain · Outcome: full domain compromise · Outcome: Tier 0 reached, control not proven · Outcome: advances toward Tier 0, does not reach it · Outcome: closed by configuration already in place · Ringed: where the route starts · Validated: executed end to end

The same shapes and lines are used on every route diagram and on the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE TEMPLATE PRIVILEGE ESCALATION (ADCS ESC1) CONFIRMED

The vulnerable certificate authority was reachable and the escalation itself ran to completion. This exposure is proven, not estimated.

ADCS ESC1: the certificate template ESC1 allows group Domain Users to request certificates where the subject alternative name (SAN) is supplied by the requester. By specifying a privileged user (e.g. Domain Admin) in the SAN, the attacker obtains a certificate that authenticates as that user via PKINIT, fully compromising Domain Admins.

REMEDIATION

- Disable 'Enrollee supplies subject' on template ESC1, or require manager approval for enrollment.
- Restrict enrollment permissions on ESC1 to authorized identities only.
- Apply the KB5014754 enforcement mode on the CA to block weak SAN mapping.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm template ESC1 is ESC1-vulnerable: it authorizes client authentication AND lets the enrollee supply the subject
(SAN). The CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT bit is 0x1 in msPKI-Certificate-Name-Flag:
certutil -v -template ESC1 |
  Select-String -Pattern 'ENROLLEE_SUPPLIES_SUBJECT', 'Client Authentication', 'msPKI-Certificate-Name-Flag'
```

LINUX / PENTESTER

```
Enumerate ADCS and confirm ESC1 is flagged vulnerable (read-only collection, no request issued):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Domain Admins is a direct or nested member of Administrators. All privileges held by Administrators, including any onward attack-path edges, are inherited by Domain Admins.

REMEDIATION

- No change is required at this step: Domain Admins is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of Domain Admins. Remediate there.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

Administrators holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

REMEDIATION

- No change is required at this step: Administrators is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of Administrators. Remediate there.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

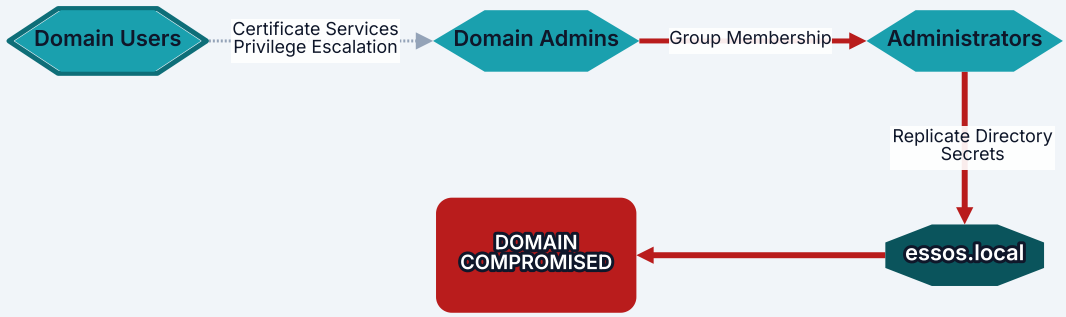
2 technique steps across a 3-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Certificate Services Privilege Escalation, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE SERVICES PRIVILEGE ESCALATION (ADCS ESC2) THEORETICAL

ADCS ESC2 abuses a certificate template whose extended key usage is either the Any Purpose OID (2.5.29.37.0) or empty. A certificate with no usage restriction can be presented for client authentication, so group Domain Users (who holds enrollment rights on ESC2 and faces no manager approval and no enrollment-agent signature requirement) can request a certificate and then use it to log in as another identity. Unlike ESC1 the subject is not supplied by the requester; the escalation instead depends on how the certificate is later mapped to an account (for example paired with a weak certificate-to-account mapping), which lets the attacker pivot toward Domain Admins.

REMEDIATION

- Remove the Any Purpose EKU from ESC2 and assign only the specific extended key usages the template legitimately needs; a template used for authentication should carry a restricted EKU set, never Any Purpose or an empty EKU list.
- Require CA manager approval (set the CT_FLAG_PEND_ALL_REQUESTS enrollment flag) so a certificate is never issued automatically from this template.
- Restrict enrollment permissions on ESC2 to only the identities that must request it, and remove enrollment rights from broad groups such as Domain Users and Authenticated Users.
- Apply the KB5014754 strong certificate mapping enforcement on domain controllers so a certificate cannot be silently mapped to a higher-privileged account.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm ESC2 grants the Any Purpose EKU (or no EKU) and lets a low-privileged principal enroll without manager approval:
certutil -v -template ESC2 |
  Select-String -Pattern 'Any Purpose', 'Extended Key Usage', 'msPKI-Enrollment-Flag', 'msPKI-RA-Signature'
# List the enrollment ACL on the template object:
Get-ADObject -LDAPFilter '(cn=ESC2)' -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$((Get-
ADRootDSE).configurationNamingContext)" -Properties nTSecurityDescriptor
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm ESC2 is flagged ESC2 (no request issued):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

2 technique steps across a 3-hop chain (1 hop is structural group membership).

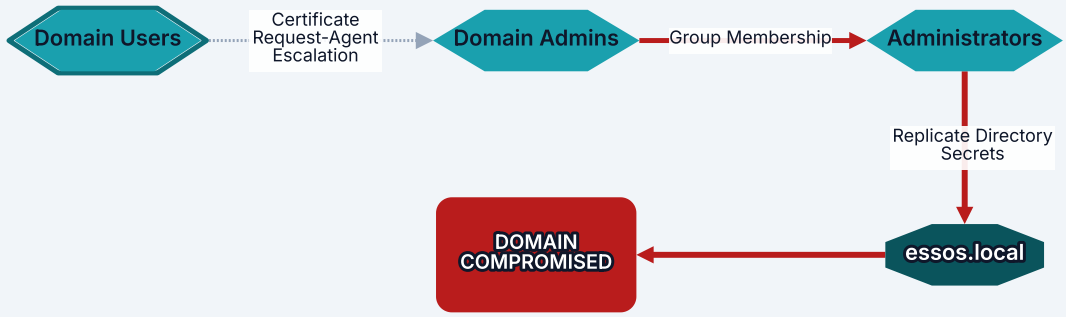
○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE | PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Certificate Request-Agent Escalation, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE REQUEST-AGENT ESCALATION (ADCS ESC3) THEORETICAL

ADCS ESC3 abuses a certificate template that carries the Certificate Request Agent EKU (1.3.6.1.4.1.311.20.2.1). The attack has two halves. First, group Domain Users enrolls in the agent template (it has enrollment rights, no manager approval, and no enrollment-agent signature requirement) and receives an enrollment-agent certificate. Second, the attacker uses that agent certificate to co-sign a request on a second template that permits enrollment-on-behalf-of, minting a client-authentication certificate for a privileged target. Authenticating with that certificate via PKINIT then impersonates the target and compromises Domain Admins.

REMEDIATION

- Restrict enrollment on the enrollment-agent template ESC3-CRA to a small, explicitly approved set of certificate-management operators; remove enrollment rights from Domain Users and Authenticated Users.
- Require CA manager approval on ESC3-CRA so an enrollment-agent certificate is never issued automatically.
- On the CA, configure enrollment-agent restrictions (Restricted Enrollment Agents on the Enrollment Agents tab in the CA properties) so an agent certificate can only enroll for a defined set of templates and target principals.
- Audit every template that accepts an enrollment-agent signature and remove the on-behalf-of capability where it is not required.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm ESC3-CRA grants the Certificate Request Agent EKU and is enrollable without approval:
certutil -v -template ESC3-CRA |
  Select-String -Pattern 'Certificate Request Agent', '1.3.6.1.4.1.311.20.2.1', 'msPKI-Enrollment-Flag', 'msPKI-RA-
Signature'
# Check which templates accept an enrollment-agent co-signature (msPKI-RA-Application-Policies references the agent EKU):
Get-ADObject -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$((Get-
ADRootDSE).configurationNamingContext)" -LDAPFilter '(objectClass=pKICertificateTemplate)' -Properties msPKI-RA-Application-
Policies
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm the agent template is flagged ESC3 (no certificate requested):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

2 technique steps across a 3-hop chain (1 hop is structural group membership).

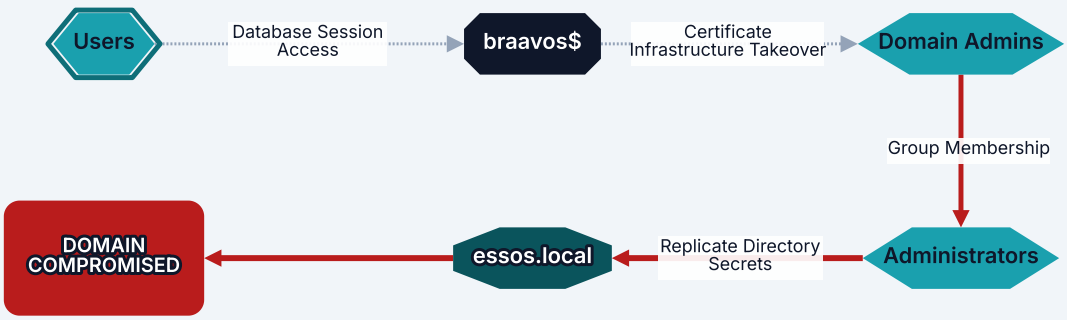
○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Users → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Users, an attacker can reach essos.local in 4 steps. The path chains Database Session Access, Certificate Infrastructure Takeover, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. DATABASE SESSION ACCESS (SQLACCESS) THEORETICAL

This step indicates Users can perform 'SQLAccess' against braavos$, enabling further escalation.

2. **CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5)** THEORETICAL

ADCS ESC5 covers write-level control (GenericAll, GenericWrite, WriteDacl, WriteOwner, or Owns) over the high-value PKI objects that underpin certificate trust: the NTAuthStore (which lists the CAs trusted for domain client authentication), the Root CA and AIA CA objects, and the Enterprise CA object itself. computer braavos$ with such a right on Domain Admins can, for example, publish an attacker-controlled CA into NTAuth so that certificates it issues are trusted for logon, or otherwise reconfigure the CA to mint authentication certificates for privileged identities. Because these objects govern the whole PKI trust chain, compromising one is equivalent to controlling certificate-based authentication across the domain.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the ACL on the PKI object and confirm a non-Tier-0 principal holds write access. For the NTAuth store:
$cfg = (Get-ADRootDSE).configurationNamingContext
(Get-Acl "AD:CN=NTAuthCertificates,CN=Public Key Services,CN=Services,$cfg").Access |
  Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|GenericWrite|WriteDacl|WriteOwner' } |
  Format-Table IdentityReference, ActiveDirectoryRights
# List the CAs currently trusted for authentication:
certutil -viewstore -enterprise NTAuth
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm the PKI object write finding (nothing published):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/access-controls
```

3. **GROUP MEMBERSHIP (MEMBEROF)** STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

4. **REPLICATE DIRECTORY SECRETS (DCSYNC)** CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

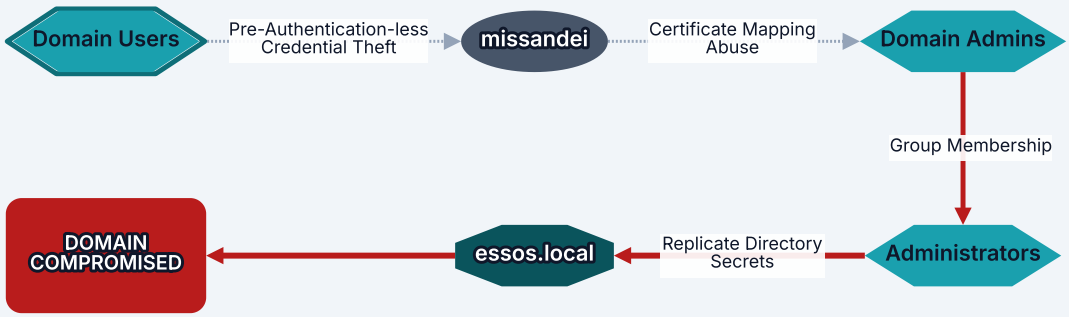
3 technique steps across a 4-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 4 steps. The path chains Pre-Authentication-less Credential Theft, Certificate Mapping Abuse, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting targets accounts, in this path missandei, that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including Domain Users) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for missandei.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

2. CERTIFICATE MAPPING ABUSE (ADCS ESC9) THEORETICAL

ADCS ESC9 abuses a certificate template whose msPKI-Enrollment-Flag includes CT_FLAG_NO_SECURITY_EXTENSION, which tells the CA NOT to embed the szOID_NTDS_CA_SECURITY_EXT SID security extension in the issued certificate. Without that extension the domain controller falls back to weak, name-based certificate-to-account mapping. user missandei, holding enrollment rights on the client authentication template ESC9 with no manager approval, can (typically after altering a controllable account's UPN, or combined with a shadow-credential / password-reset primitive) enroll a certificate that a DC then maps to a privileged victim, authenticating as them and compromising Domain Admins.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm ESC9 sets CT_FLAG_NO_SECURITY_EXTENSION (0x80000 in msPKI-Enrollment-Flag) and grants client authentication:
$cfg = (Get-ADRootDSE).configurationNamingContext
Get-ADObject -LDAPFilter '(cn=ESC9)' -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$cfg" -
Properties msPKI-Enrollment-Flag, pKIExtendedKeyUsage |
  Format-List cn, msPKI-Enrollment-Flag, pKIExtendedKeyUsage
# Confirm StrongCertificateBindingEnforcement is enforced on DCs (KB5014754):
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Services\Kdc' -Name StrongCertificateBindingEnforcement
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm ESC9 is flagged ESC9 (no certificate requested):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

3. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

4. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

3 technique steps across a 4-hop chain (1 hop is structural group membership).

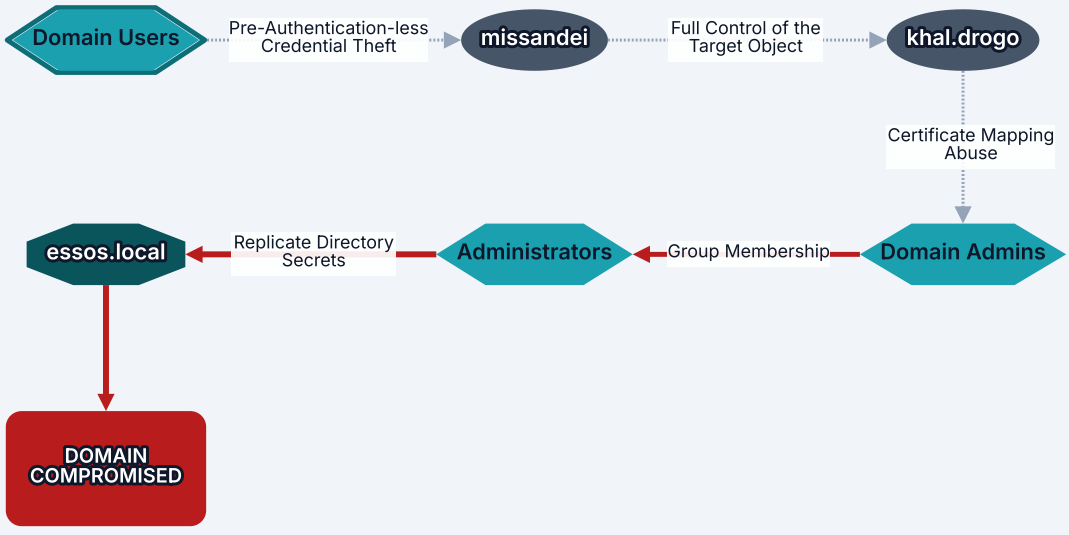
○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 5 steps. The path chains Pre-Authentication-less Credential Theft, Full Control of the Target Object, Certificate Mapping Abuse, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.

ADscan consolidated 2 equivalent candidate routes into this one attack path; ADscan proved the entry step, but did not walk it to full domain compromise. Also reachable via Administrators, Domain Admins, khal.drogo, missandei, viserys.targaryen.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll grants user missandei full read and write control over user khal.drogo. The source can reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink) to obtain a PKINIT certificate, or set a servicePrincipalName to make the account kerberoastable, any of which leads to full compromise of khal.drogo.

REMEDIATION

- Remove the GenericAll ACE that missandei holds over khal.drogo. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=khal.drogo)'`, list what missandei currently holds on it with `(Get-Acl "AD:\CN=khal.drogo,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*missandei*'`, then delete those entries with `dsacls "CN=khal.drogo,CN=Users,DC=essos,DC=local" /R "ESSOS\missandei"`. Before: the entry reads ActiveDirectoryRights=GenericAll, AccessControlType=Allow. After: the same query returns nothing for that principal.
- Grant back only the rights the delegation actually needs, never full control. GenericAll carries password reset, key-credential write (Shadow Credentials), servicePrincipalName write and script-path write in one ACE, so any one of them left in place restores the takeover: which is why narrowing it is the fix and auditing it is not. Use the Delegation of Control wizard, or a scoped ACE such as `dsacls "CN=khal.drogo,CN=Users,DC=essos,DC=local" /G "ESSOS\<helpdeskGroup>:CA;Reset Password"` when password reset is genuinely required.
- Confirm no other principal holds equivalent control over the same object: `(Get-Acl "AD:\CN=khal.drogo,CN=Users,DC=essos,DC=local").Access | Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|WriteDacl|WriteOwner' -and $_.AccessControlType -eq 'Allow' }`. Anything returned other than Domain Admins, Enterprise Admins or SYSTEM is the same finding under a different principal.
- Add khal.drogo to Protected Users, and keep Tier 0 accounts out of the organisational units that ordinary delegation applies to, so a future broad grant cannot reach them by inheritance.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei holds GenericAll over khal.drogo. Resolve the target DN, then read the ACL and filter to the principal:
$dn = 'CN=khal.drogo,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm missandei has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object khal.drogo --attr nTSecurityDescriptor --resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

3. CERTIFICATE MAPPING ABUSE (ADCS ESC9) THEORETICAL

ADCS ESC9: certificate template ESC9 carries the CT_FLAG_NO_SECURITY_EXTENSION flag, so a certificate khal.drogo enrolls omits the SID binding and can be mapped to a privileged account.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm ESC9 sets CT_FLAG_NO_SECURITY_EXTENSION (0x80000 in msPKI-Enrollment-Flag) and grants client authentication:
$cfg = (Get-ADRootDSE).configurationNamingContext
Get-ADObject -LDAPFilter '(cn=ESC9)' -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$cfg" -
Properties msPKI-Enrollment-Flag, pKIExtendedKeyUsage |
  Format-List cn, msPKI-Enrollment-Flag, pKIExtendedKeyUsage
# Confirm StrongCertificateBindingEnforcement is enforced on DCs (KB5014754):
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Services\Kdc' -Name StrongCertificateBindingEnforcement
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm ESC9 is flagged ESC9 (no certificate requested):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

How this technique works: Certificate Mapping Abuse (ADCS ESC9), in Techniques behind these attack paths.

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

5. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

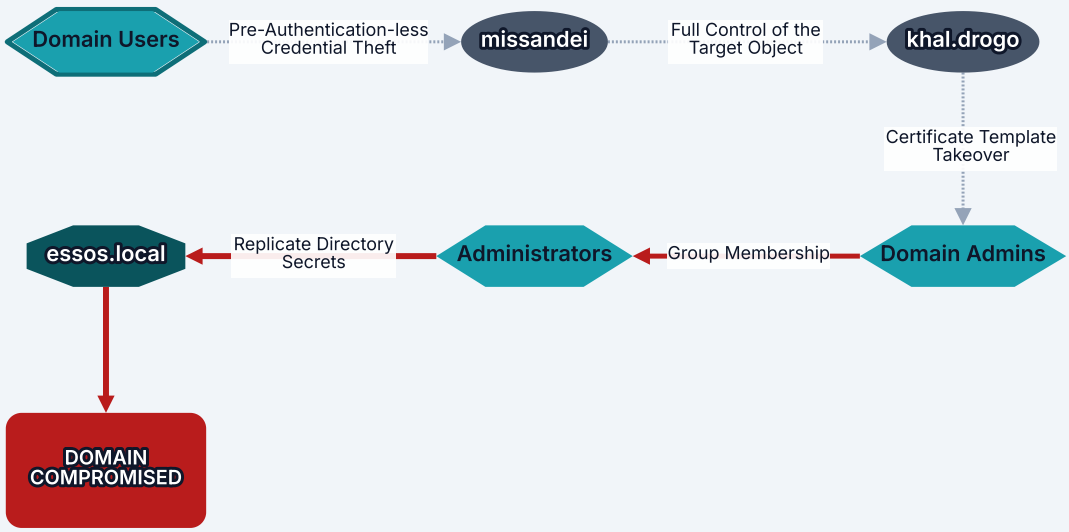
4 technique steps across a 5-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 5 steps. The path chains Pre-Authentication-less Credential Theft, Full Control of the Target Object, Certificate Template Takeover, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user missandei has full control over user khal.drogo.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei holds GenericAll over khal.drogo. Resolve the target DN, then read the ACL and filter to the principal:
$dn = 'CN=khal.drogo,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm missandei has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object khal.drogo --attr nTSecurityDescriptor --resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

3. CERTIFICATE TEMPLATE TAKEOVER (ADCS ESC4) THEORETICAL

ADCS ESC4 is a control-plane weakness: user khal.drogo holds a write-equivalent right (GenericAll, GenericWrite, WriteDacl, WriteOwner, or Owns) over the certificate template object ESC4. Any of these lets the attacker modify the template's attributes (for example enabling ENROLLEE_SUPPLIES_SUBJECT, adding a client authentication EKU, granting itself enrollment rights, and clearing the manager-approval flag), which turns the template into the ESC1 condition. The attacker then enrolls, supplies a privileged subject, and authenticates with the issued certificate to compromise Domain Admins. Write access on the template alone is sufficient; no pre-existing template flag is required.

REMEDIATION

- Remove the excessive write rights on ESC4: using dsacls or Set-Acl on the template object, revoke GenericAll / GenericWrite / WriteDacl / WriteOwner from any non-Tier-0 principal so only PKI administrators can modify it.
- Set the template owner to a Tier-0 PKI administration group rather than an ordinary user or an over-broad group.
- After removing the rights, inspect ESC4 for any ESC1-style changes the attacker may already have applied (enrollee-supplies-subject, added client-auth EKU, relaxed approval) and restore the intended secure configuration.
- Audit the ACLs of every certificate template and PKI container with Get-Acl / dsacls and treat template write access as a Tier-0 privilege.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the ACL on ESC4 and confirm a non-privileged principal holds a write-equivalent right (GenericAll / GenericWrite /
WriteDacl / WriteOwner):
$cfg = (Get-ADRootDSE).configurationNamingContext
$tmpl = Get-ADObject -LDAPFilter '(cn=ESC4)' -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$cfg"
(Get-Acl "AD:$($tmpl.DistinguishedName)").Access |
  Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|GenericWrite|WriteDacl|WriteOwner' } |
  Format-Table IdentityReference, ActiveDirectoryRights
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm ESC4 is flagged ESC4 with the write principal listed (no template modified):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/access-controls
```

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

5. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

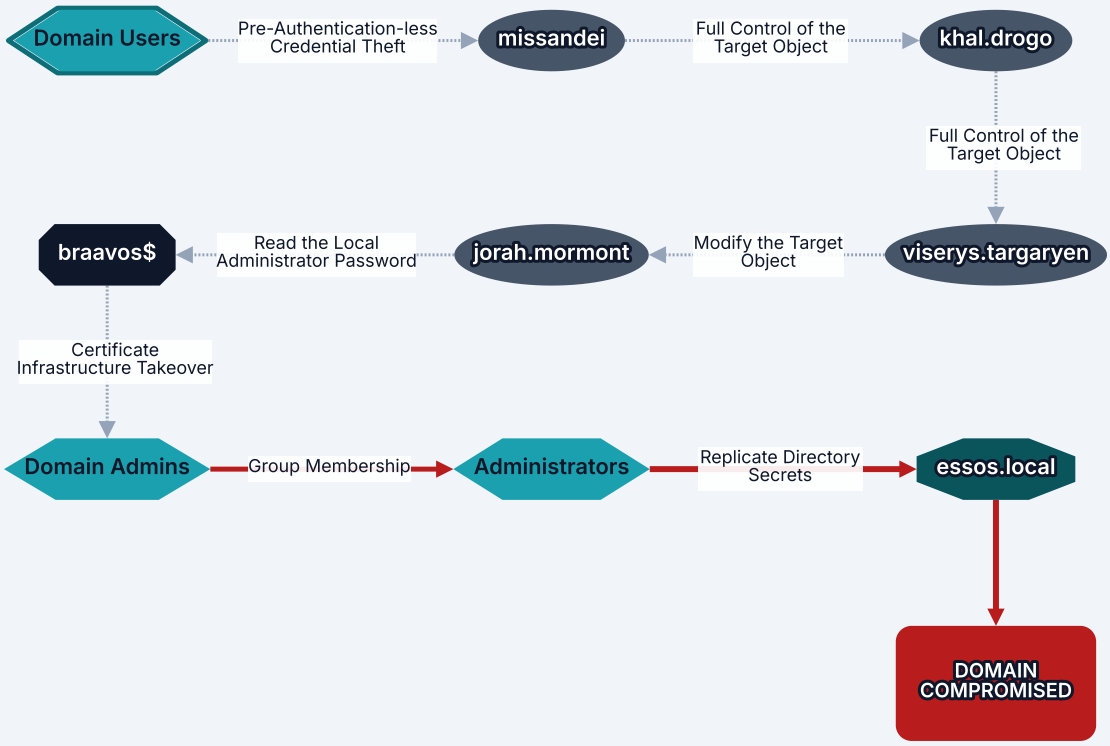
4 technique steps across a 5-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 8 steps. The path chains Pre-Authentication-less Credential Theft, Full Control of the Target Object, Modify the Target Object, Read the Local Administrator Password, Certificate Infrastructure Takeover, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user missandei has full control over user khal.drogo.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei holds GenericAll over khal.drogo. Resolve the target DN, then read the ACL and filter to the principal:
$dn = 'CN=khal.drogo,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm missandei has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object khal.drogo --attr nTSecurityDescriptor --resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user khal.drogo has full control over user viserys.targaryen.

REMEDIATION

- Remove the GenericAll ACE that khal.drogo holds over viserys.targaryen. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=viserys.targaryen)'`, list what khal.drogo currently holds on it with `(Get-Acl "AD:\CN=viserys.targaryen,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*khal.drogo*'`, then delete those entries with `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /R "ESSOS\khal.drogo"`. Before: the entry reads ActiveDirectoryRights=GenericAll, AccessControlType=Allow. After: the same query returns nothing for that principal.
- Grant back only the rights the delegation actually needs, never full control. GenericAll carries password reset, key-credential write (Shadow Credentials), servicePrincipalName write and script-path write in one ACE, so any one of them left in place restores the takeover: which is why narrowing it is the fix and auditing it is not. Use the Delegation of Control wizard, or a scoped ACE such as `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /G "ESSOS\<helpdeskGroup>:CA;Reset Password"` when password reset is genuinely required.
- Confirm no other principal holds equivalent control over the same object: `(Get-Acl "AD:\CN=viserys.targaryen,CN=Users,DC=essos,DC=local").Access | Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|WriteDacl|WriteOwner' -and $_.AccessControlType -eq 'Allow' }`. Anything returned other than Domain Admins, Enterprise Admins or SYSTEM is the same finding under a different principal.
- Add viserys.targaryen to Protected Users, and keep Tier 0 accounts out of the organisational units that ordinary delegation applies to, so a future broad grant cannot reach them by inheritance.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm khal.drogo holds GenericAll over viserys.targaryen. Resolve the target DN, then read the ACL and filter to the
principal:
$dn = 'CN=viserys.targaryen,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*khal.drogo*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm khal.drogo has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object viserys.targaryen --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

4. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: viserys.targaryen can modify user jorah.mormont's attributes, enabling takeover via a password reset, Shadow Credentials or a servicePrincipalName.

REMEDIATION

- Remove the GenericWrite ACE that viserys.targaryen holds on jorah.mormont. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=jorah.mormont)'`, list what viserys.targaryen currently holds on it with `(Get-Acl "AD:\CN=jorah.mormont,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*viserys.targaryen*'`, then delete those entries with `dsacls "CN=jorah.mormont,CN=Users,DC=essos,DC=local" /R "ESSOS\viserys.targaryen"`. Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal.
- Grant back only the specific attributes the delegation needs, rather than write access to the object. GenericWrite is a takeover because three of the attributes it covers each hand over the account on their own: msDS-KeyCredentialLink (a certificate the account can then authenticate with), servicePrincipalName (which exposes the account's password hash to offline cracking), and msDS-AllowedToActOnBehalfOfOtherIdentity (which lets another host impersonate any user to this one). A scoped grant such as `dsacls "CN=jorah.mormont,CN=Users,DC=essos,DC=local" /G "ESSOS\<group>:WP;description"` gives the delegation its attribute and none of those.
- Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on jorah.mormont: `Get-ADObject "CN=jorah.mormont,CN=Users,DC=essos,DC=local" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity`. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with `Set-ADObject "CN=jorah.mormont,CN=Users,DC=essos,DC=local" -Clear <attribute>`.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm viserys.targaryen can write jorah.mormont's attributes. Resolve the DN, then read the ACL and filter to the
principal:
$dn = 'CN=jorah.mormont,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*viserys.targaryen*' -and $_.ActiveDirectoryRights -match
'GenericWrite|WriteProperty' }
# An Allow row with GenericWrite (or broad WriteProperty) confirms it.
```

LINUX / PENTESTER

```
List the objects viserys.targaryen can write and confirm jorah.mormont is among them (read-only), or read the target's SD
directly:
bloodyAD --host <dc_ip> -d essos.local -u viserys.targaryen -p <pass> get writable --detail
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these attack paths.

5. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

The ReadLAPSPassword edge means jorah.mormont has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of braavos$. jorah.mormont simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to braavos$.

6. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

ADCS ESC5: braavos$ holds write access over a PKI infrastructure object (Domain Admins), letting it tamper with the CA trust configuration and forge or trust attacker-controlled certificates.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the ACL on the PKI object and confirm a non-Tier-0 principal holds write access. For the NTAuth store:
$cfg = (Get-ADRootDSE).configurationNamingContext
(Get-Acl "AD:CN=NTAuthCertificates,CN=Public Key Services,CN=Services,$cfg").Access |
  Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|GenericWrite|WriteDacl|WriteOwner' } |
  Format-Table IdentityReference, ActiveDirectoryRights
# List the CAs currently trusted for authentication:
certutil -viewstore -enterprise NTAuth
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm the PKI object write finding (nothing published):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/access-controls
```

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these attack paths.

7. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

8. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

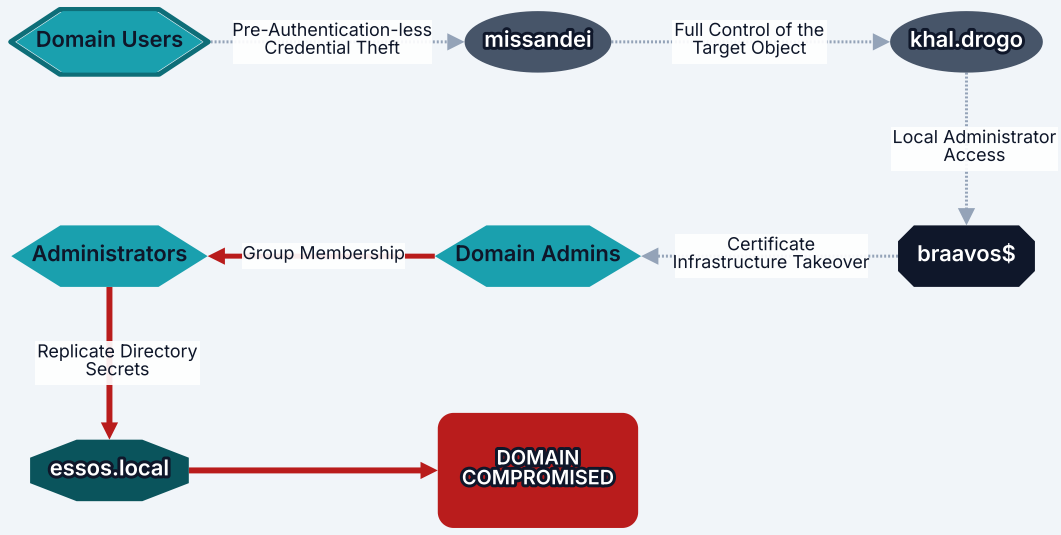
7 technique steps across a 8-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 6 steps. The path chains Pre-Authentication-less Credential Theft, Full Control of the Target Object, Local Administrator Access, Certificate Infrastructure Takeover, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user missandei has full control over user khal.drogo.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei holds GenericAll over khal.drogo. Resolve the target DN, then read the ACL and filter to the principal:
$dn = 'CN=khal.drogo,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm missandei has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object khal.drogo --attr nTSecurityDescriptor --resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

3. LOCAL ADMINISTRATOR ACCESS (ADMINTO) THEORETICAL

Local administrator membership on a host is total control of that machine. user khal.drogo that is a local admin on braavos$ can authenticate over SMB to the ADMIN$/C$ shares, install and start a service, schedule a task, or invoke WMI/DCOM to execute commands as NT AUTHORITY\SYSTEM. From SYSTEM it can read the SAM and LSA secrets, dump credentials cached in LSASS, and steal the tokens of any other user currently logged on, turning one admin relationship into a foothold for lateral movement across the domain. The right is granted either by explicit membership in the host's local Administrators group or by a domain group nested into it (often through a widely-scoped GPO-pushed 'workstation admins' group), which is why a single over-broad group can expose hundreds of machines at once.

REMEDIATION

- Enumerate the effective local administrators on the host and remove every principal that does not require them: Invoke-Command -ComputerName braavos.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Administrators' }.
- Replace broad, GPO-pushed 'all workstation admins' groups with narrowly-scoped, per-tier groups so a single group cannot make one account admin on hundreds of machines; audit the nesting with Get-ADGroupMember -Recursive.
- Deploy LAPS so each host has a unique, rotated local Administrator password, removing the shared-local-admin lateral-movement path.
- Enforce tier separation (ESAE): Tier-0 admins must never log on to Tier-1/Tier-2 hosts, so their credentials are never cached where a member-server compromise can reach them. Monitor Event IDs 4624/4672 for privileged logons to unexpected hosts.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the local Administrators group on braavos$ and expand nested domain groups to see who is effectively an admin:
Invoke-Command -ComputerName braavos.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Administrators' }
# Trace a domain group that is nested into local Administrators via GPO:
Get-ADGroupMember -Identity '<workstation-admins-group>' -Recursive |
  Select-Object name, objectClass
```

LINUX / PENTESTER

```
Confirm the admin relationship without dumping anything: the 'Pwn3d!' marker is printed only when the account is a local
administrator:
nxc smb braavos.essos.local -u <user> -p <pass> -d essos.local
# Reference: https://www.thehacker.recipes/ad/movement/lateral-movement
```

4. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

ADCS ESC5: braavos$ holds write access over a PKI infrastructure object (Domain Admins), letting it tamper with the CA trust configuration and forge or trust attacker-controlled certificates.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the ACL on the PKI object and confirm a non-Tier-0 principal holds write access. For the NTAuth store:
$cfg = (Get-ADRootDSE).configurationNamingContext
(Get-Acl "AD:CN=NTAuthCertificates,CN=Public Key Services,CN=Services,$cfg").Access |
  Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|GenericWrite|WriteDacl|WriteOwner' } |
  Format-Table IdentityReference, ActiveDirectoryRights
# List the CAs currently trusted for authentication:
certutil -viewstore -enterprise NTAuth
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm the PKI object write finding (nothing published):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/access-controls
```

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these attack paths.

5. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

6. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

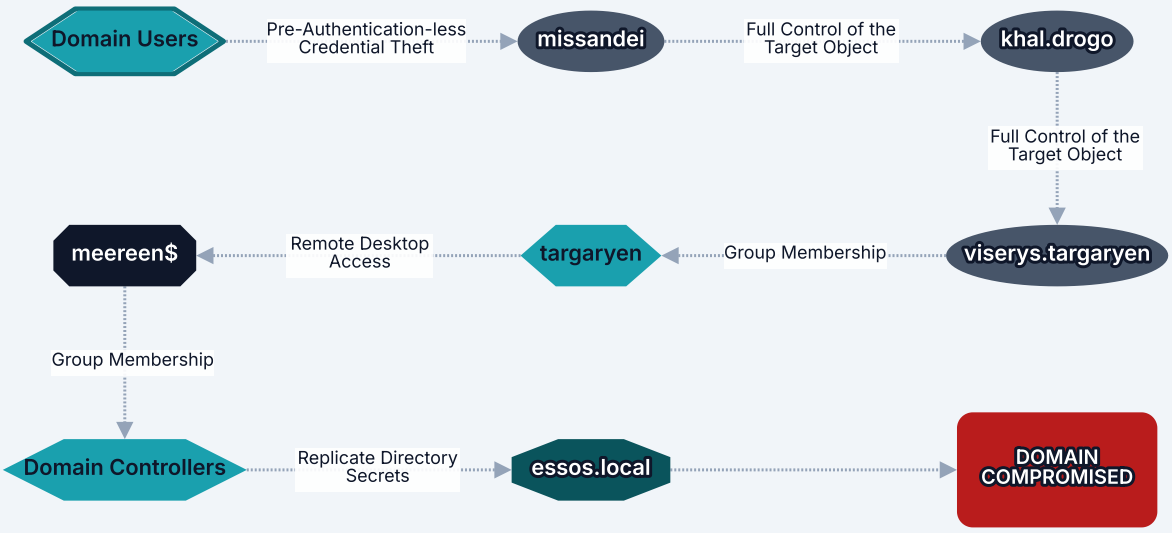
5 technique steps across a 6-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE THEORETICAL

Starting from Domain Users, an attacker can reach essos.local in 7 steps. The path chains Pre-Authentication-less Credential Theft, Full Control of the Target Object, Group Membership, Remote Desktop Access, and Replicate Directory Secrets. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user missandei has full control over user khal.drogo.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei holds GenericAll over khal.drogo. Resolve the target DN, then read the ACL and filter to the principal:
$dn = 'CN=khal.drogo,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm missandei has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object khal.drogo --attr nTSecurityDescriptor --resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user khal.drogo has full control over user viserys.targaryen.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm khal.drogo holds GenericAll over viserys.targaryen. Resolve the target DN, then read the ACL and filter to the
principal:
$dn = 'CN=viserys.targaryen,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*khal.drogo*' -and $_.ActiveDirectoryRights -match 'GenericAll' }
# A row with ActiveDirectoryRights=GenericAll, AccessControlType=Allow confirms the finding.
```

LINUX / PENTESTER

```
Read the target's security descriptor and confirm khal.drogo has full control (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object viserys.targaryen --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these attack paths.

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: viserys.targaryen is a member of Targaryen and inherits its privileges.

REMEDIATION

- Remove viserys.targaryen from Targaryen if the membership is not strictly required: Remove-ADGroupMember -Identity 'Targaryen' -Members 'viserys.targaryen'.
- If the membership IS required, scope what Targaryen can reach instead: review every object whose DACL grants rights to Targaryen and tighten the over-broad grant to a named, tier-appropriate group so the inherited attack edge no longer exists.
- Audit group membership periodically (Event ID 4728/4729/4756) and enforce tiering boundaries.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

5. REMOTE DESKTOP ACCESS (CANRDP) THEORETICAL

Membership in the Remote Desktop Users group (or local administrator rights) lets group Targaryen establish an interactive RDP session on meereen$. An interactive logon is more powerful than a network logon: the account gets a full desktop, its credentials are cached in LSASS for the life of the session, and any other user already logged on interactively has their tokens and cached secrets exposed to anyone who reaches SYSTEM on that box. RDP is a sanctioned administration channel, so the traffic itself blends in: the risk is who can reach it and what privilege they land with. If Restricted Admin mode is not enforced, the interactive credentials are recoverable, making a single RDP foothold a pivot for credential theft and onward lateral movement.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List who may log on via RDP: the local Remote Desktop Users group plus anyone in local Administrators:
Invoke-Command -ComputerName meereen.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Remote Desktop Users' }
# Confirm the RDP service is enabled and check whether NLA is required:
Get-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Terminal Server' -Name fDenyTSConnections
```

LINUX / PENTESTER

```
Non-destructive check that the account is permitted an interactive RDP logon (no session opened):
nxc rdp meereen.essos.local -u <user> -p <pass> -d essos.local
# Reference: https://www.thehacker.recipes/ad/movement/lateral-movement
```

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: meereen$ is a member of Domain Controllers and inherits its privileges.

REMEDIATION

- No change is required at this step: meereen$ is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of meereen$. Remediate there.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Domain Controllers holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa-
and 1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Domain Controllers*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Domain Controllers has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

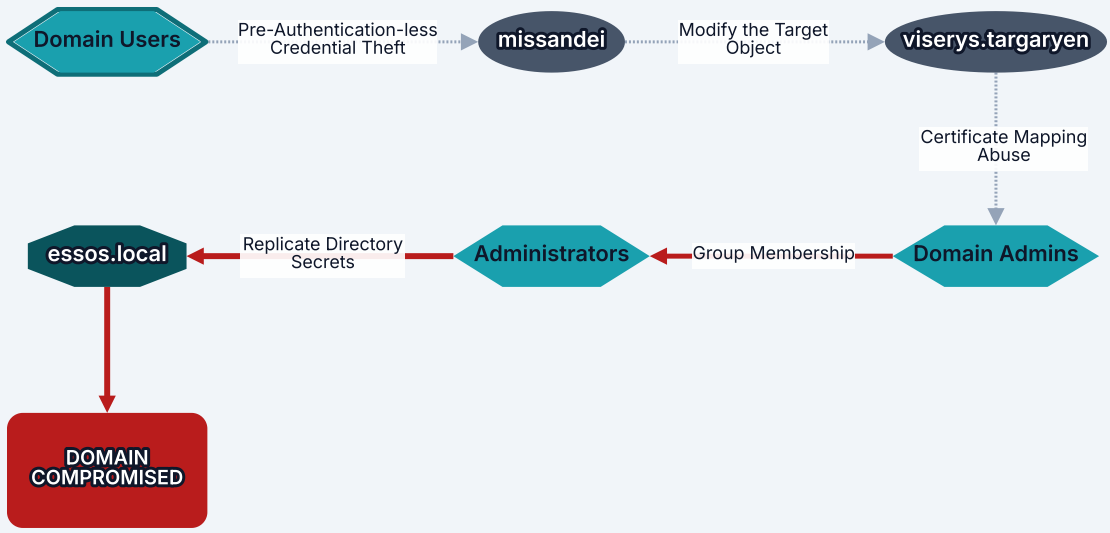
5 technique steps across a 7-hop chain (2 hops are structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 5 steps. The path chains Pre-Authentication-less Credential Theft, Modify the Target Object, Certificate Mapping Abuse, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite gives user missandei the ability to modify most attributes of user viserys.targaryen. The source can reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink) to obtain a PKINIT certificate, or set a servicePrincipalName to make the account kerberoastable, any of which leads to full compromise of viserys.targaryen.

REMEDIATION

- Remove the GenericWrite ACE that missandei holds on viserys.targaryen. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=viserys.targaryen)'`, list what missandei currently holds on it with `(Get-Acl "AD:\CN=viserys.targaryen,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*missandei*'`, then delete those entries with `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /R "ESSOS\missandei"`. Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal.
- Grant back only the specific attributes the delegation needs, rather than write access to the object. GenericWrite is a takeover because three of the attributes it covers each hand over the account on their own: msDS-KeyCredentialLink (a certificate the account can then authenticate with), servicePrincipalName (which exposes the account's password hash to offline cracking), and msDS-AllowedToActOnBehalfOfOtherIdentity (which lets another host impersonate any user to this one). A scoped grant such as `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /G "ESSOS\<group>:WP;description"` gives the delegation its attribute and none of those.
- Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on viserys.targaryen: `Get-ADObject "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity`. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with `Set-ADObject "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" -Clear <attribute>`.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei can write viserys.targaryen's attributes. Resolve the DN, then read the ACL and filter to the principal:
$dn = 'CN=viserys.targaryen,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericWrite|WriteProperty'
}
# An Allow row with GenericWrite (or broad WriteProperty) confirms it.
```

LINUX / PENTESTER

```
List the objects missandei can write and confirm viserys.targaryen is among them (read-only), or read the target's SD
directly:
bloodyAD --host <dc_ip> -d essos.local -u missandei -p <pass> get writable --detail
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

3. CERTIFICATE MAPPING ABUSE (ADCS ESC9) THEORETICAL

ADCS ESC9: certificate template ESC9 carries the CT_FLAG_NO_SECURITY_EXTENSION flag, so a certificate viserys.targaryen enrolls omits the SID binding and can be mapped to a privileged account.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm ESC9 sets CT_FLAG_NO_SECURITY_EXTENSION (0x80000 in msPKI-Enrollment-Flag) and grants client authentication:
$cfg = (Get-ADRootDSE).configurationNamingContext
Get-ADObject -LDAPFilter '(cn=ESC9)' -SearchBase "CN=Certificate Templates,CN=Public Key Services,CN=Services,$cfg" -
Properties msPKI-Enrollment-Flag, pKIExtendedKeyUsage |
  Format-List cn, msPKI-Enrollment-Flag, pKIExtendedKeyUsage
# Confirm StrongCertificateBindingEnforcement is enforced on DCs (KB5014754):
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Services\Kdc' -Name StrongCertificateBindingEnforcement
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm ESC9 is flagged ESC9 (no certificate requested):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/certificate-templates
```

How this technique works: Certificate Mapping Abuse (ADCS ESC9), in Techniques behind these attack paths.

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

5. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

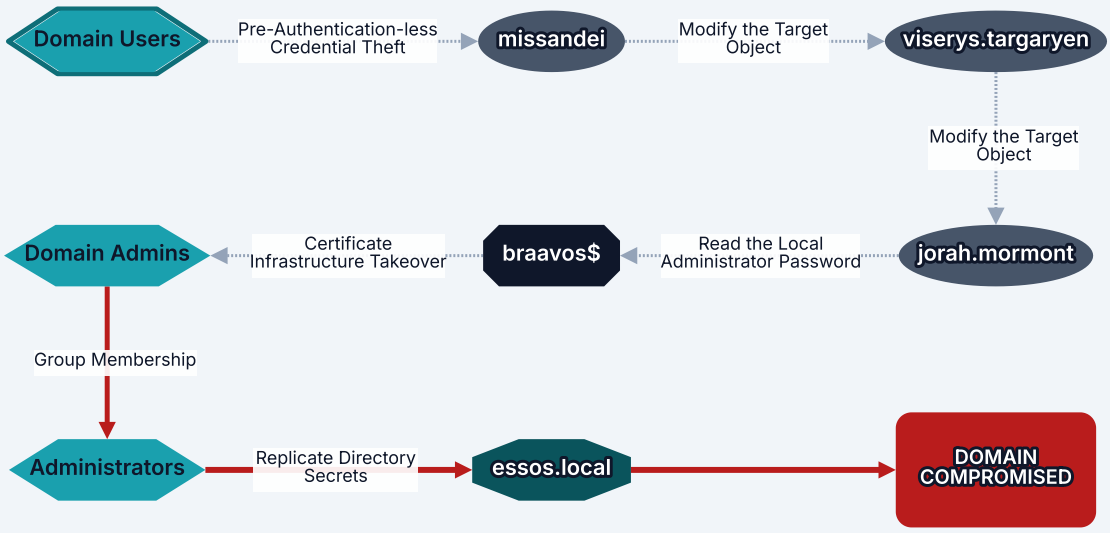
4 technique steps across a 5-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE PARTIALLY VALIDATED

Starting from Domain Users, an attacker can reach essos.local in 7 steps. The path chains Pre-Authentication-less Credential Theft, Modify the Target Object, Read the Local Administrator Password, Certificate Infrastructure Takeover, Group Membership, and Replicate Directory Secrets. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: missandei can modify user viserys.targaryen's attributes, enabling takeover via a password reset, Shadow Credentials or a servicePrincipalName.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei can write viserys.targaryen's attributes. Resolve the DN, then read the ACL and filter to the principal:
$dn = 'CN=viserys.targaryen,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericWrite|WriteProperty'
}
# An Allow row with GenericWrite (or broad WriteProperty) confirms it.
```

LINUX / PENTESTER

```
List the objects missandei can write and confirm viserys.targaryen is among them (read-only), or read the target's SD
directly:
bloodyAD --host <dc_ip> -d essos.local -u missandei -p <pass> get writable --detail
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these attack paths.

3. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: viserys.targaryen can modify user jorah.mormont's attributes, enabling takeover via a password reset, Shadow Credentials or a servicePrincipalName.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm viserys.targaryen can write jorah.mormont's attributes. Resolve the DN, then read the ACL and filter to the
principal:
$dn = 'CN=jorah.mormont,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*viserys.targaryen*' -and $_.ActiveDirectoryRights -match
'GenericWrite|WriteProperty' }
# An Allow row with GenericWrite (or broad WriteProperty) confirms it.
```

LINUX / PENTESTER

```
List the objects viserys.targaryen can write and confirm jorah.mormont is among them (read-only), or read the target's SD
directly:
bloodyAD --host <dc_ip> -d essos.local -u viserys.targaryen -p <pass> get writable --detail
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these attack paths.

4. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: jorah.mormont can read the local administrator password of braavos$ from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these attack paths.

5. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

ADCS ESC5: braavos$ holds write access over a PKI infrastructure object (Domain Admins), letting it tamper with the CA trust configuration and forge or trust attacker-controlled certificates.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List the ACL on the PKI object and confirm a non-Tier-0 principal holds write access. For the NTAuth store:
$cfg = (Get-ADRootDSE).configurationNamingContext
(Get-Acl "AD:CN=NTAuthCertificates,CN=Public Key Services,CN=Services,$cfg").Access |
  Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|GenericWrite|WriteDacl|WriteOwner' } |
  Format-Table IdentityReference, ActiveDirectoryRights
# List the CAs currently trusted for authentication:
certutil -viewstore -enterprise NTAuth
```

LINUX / PENTESTER

```
Read-only ADCS enumeration; confirm the PKI object write finding (nothing published):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/access-controls
```

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these attack paths.

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: Domain Admins is a member of Administrators and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: Administrators can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Administrators holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa- and
1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Administrators*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Administrators has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

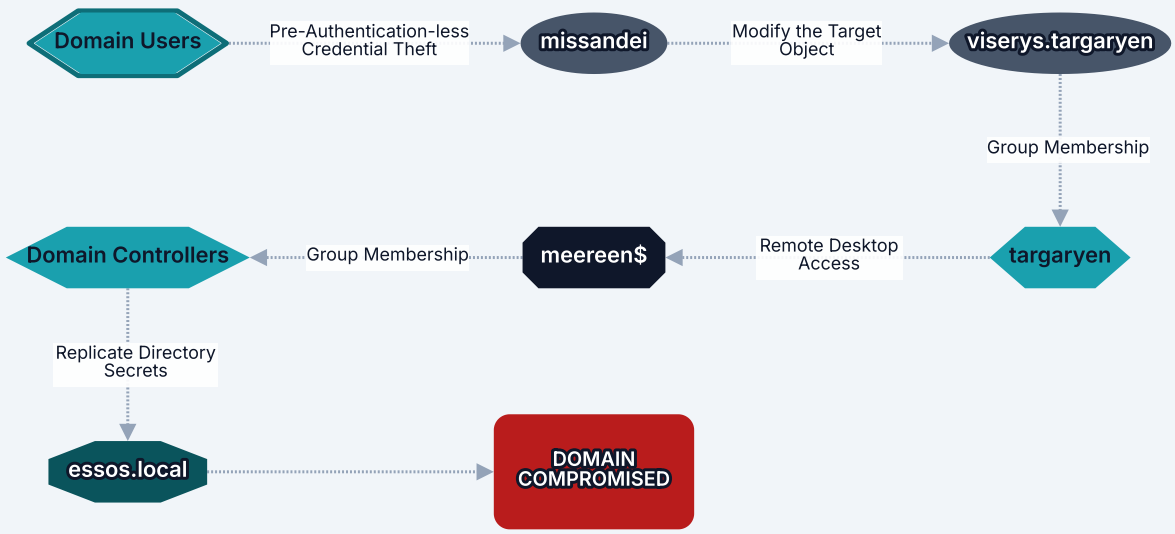
6 technique steps across a 7-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE THEORETICAL

Starting from Domain Users, an attacker can reach essos.local in 6 steps. The path chains Pre-Authentication-less Credential Theft, Modify the Target Object, Group Membership, Remote Desktop Access, and Replicate Directory Secrets. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: missandei has pre-authentication disabled, so Domain Users can request an AS-REP and crack it offline.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei has pre-authentication disabled: bit 0x400000 (DONT_REQ_PREAUTH) set on userAccountControl:
Get-ADUser -Identity missandei -Properties DoesNotRequirePreAuth |
  Select-Object SamAccountName, DoesNotRequirePreAuth
# List every AS-REP-roastable account in the domain:
Get-ADUser -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=4194304)'
```

LINUX / PENTESTER

```
List accounts with pre-auth disabled (read-only enumeration):
nxc ldap <dc_ip> -u <user> -p <pass> --asreproast /dev/null
# Reference: https://www.thehacker.recipes/ad/movement/kerberos/asreproast
```

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these attack paths.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: missandei can modify user viserys.targaryen's attributes, enabling takeover via a password reset, Shadow Credentials or a servicePrincipalName.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm missandei can write viserys.targaryen's attributes. Resolve the DN, then read the ACL and filter to the principal:
$dn = 'CN=viserys.targaryen,CN=Users,DC=essos,DC=local'
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*missandei*' -and $_.ActiveDirectoryRights -match 'GenericWrite|WriteProperty'
}
# An Allow row with GenericWrite (or broad WriteProperty) confirms it.
```

LINUX / PENTESTER

```
List the objects missandei can write and confirm viserys.targaryen is among them (read-only), or read the target's SD
directly:
bloodyAD --host <dc_ip> -d essos.local -u missandei -p <pass> get writable --detail
# Reference: https://www.thehacker.recipes/ad/movement/dacl/grant-rights
```

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these attack paths.

3. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: viserys.targaryen is a member of Targaryen and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

4. REMOTE DESKTOP ACCESS (CANRDP) THEORETICAL

Targaryen can open an interactive Remote Desktop session on meereen$, landing a live desktop it can use to run tooling and reach further into the network.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
List who may log on via RDP: the local Remote Desktop Users group plus anyone in local Administrators:
Invoke-Command -ComputerName meereen.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Remote Desktop Users' }
# Confirm the RDP service is enabled and check whether NLA is required:
Get-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Terminal Server' -Name fDenyTSConnections
```

LINUX / PENTESTER

```
Non-destructive check that the account is permitted an interactive RDP logon (no session opened):
nxc rdp meereen.essos.local -u <user> -p <pass> -d essos.local
# Reference: https://www.thehacker.recipes/ad/movement/lateral-movement
```

How this technique works: Remote Desktop Access (CanRDP), in Techniques behind these attack paths.

5. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: meereen$ is a member of Domain Controllers and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

6. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Domain Controllers holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa-
and 1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Domain Controllers*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Domain Controllers has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

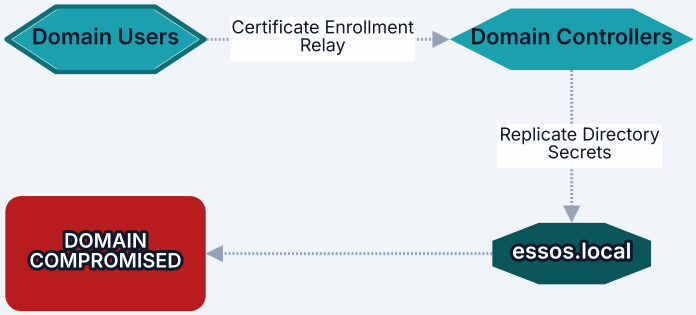
4 technique steps across a 6-hop chain (2 hops are structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED FULL DOMAIN COMPROMISE THEORETICAL

Starting from Domain Users, an attacker can reach essos.local in 2 steps. The path chains Certificate Enrollment Relay and Replicate Directory Secrets. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. **CERTIFICATE ENROLLMENT RELAY (ADCS ESC8)** THEORETICAL

ADCS ESC8 abuses the CA's HTTP web-enrollment interface (certsrv / the certificate enrollment web service), which by default accepts NTLM authentication with no channel binding. Any principal who can capture or coerce a victim's NTLM authentication (commonly a domain controller coerced via a printer-bug / EFSRPC trigger) relays that authentication to the web-enrollment endpoint and requests a client authentication certificate as the victim. A certificate for a domain controller's machine account can then be used to authenticate and replicate the directory, so ESC8 escalates straight to domain compromise of Domain Controllers. The relay only requires the victim to hold any valid domain credential, which makes it cross-forest capable.

REMEDIATION

- Enforce SMB signing and, where possible, disable NTLM in favour of Kerberos so the coercion-to-relay chain has no authentication to capture.
- Enforce LDAP signing and channel binding on domain controllers so a coerced authentication cannot be relayed to the directory either.
- Reduce which accounts can be coerced by hardening the coercion triggers (Print Spooler, EFSRPC, DFS) on domain controllers and servers.
- For the web-enrollment endpoint itself, apply the fix called out for the exact transport this route relayed over in the Web Enrollment Transport detail on this finding.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Check whether the CA offers HTTP web enrollment (the ESC8 relay surface). Confirm the Certificate Enrollment web role is
installed and whether it is bound to HTTP:
Get-WindowsFeature ADCS-Web-Enrollment, ADCS-Enroll-Web-Svc
Get-WebBinding | Where-Object { $_.protocol -eq 'http' }
# Confirm Extended Protection for Authentication (channel binding) is enforced on any HTTPS enrollment site so a relay is
defeated.
```

LINUX / PENTESTER

```
Read-only ADCS enumeration reports the web-enrollment endpoint under the CA (no relay performed):
certipy find -u <user>@essos.local -p <pass> -dc-ip <dc_ip> -vulnerable -stdout
# Reference: https://www.thehacker.recipes/ad/movement/adcs/unsigned-endpoints
```

2. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

REMEDIATION

- No change is required at this step: Domain Controllers is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of Domain Controllers. Remediate there.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Domain Controllers holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa-
and 1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Domain Controllers*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Domain Controllers has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

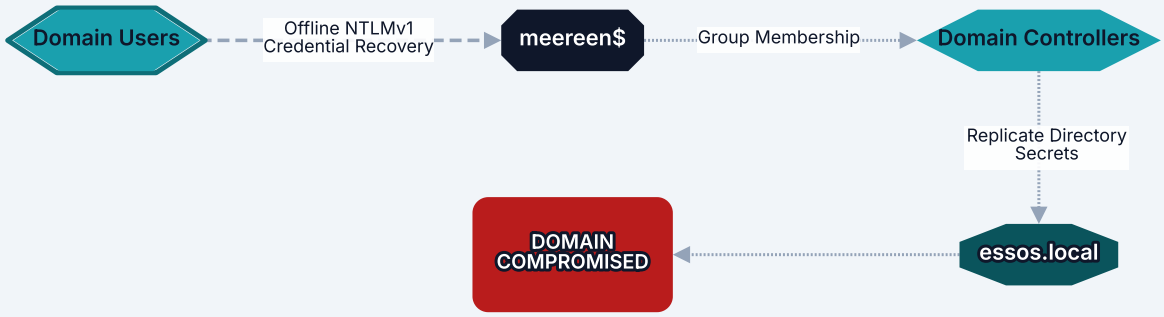
○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE NOT ASSESSED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Offline NTLMv1 Credential Recovery, Group Membership, and Replicate Directory Secrets. This attack path was not assessed in this engagement: no reachable surface was available to test the avenue.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. OFFLINE NTLMV1 CREDENTIAL RECOVERY (NTLMV1 OFFLINE CRACK)

NTLMv1 Offline Crack: Domain Users coerces meereen$, captures its NTLMv1 response, and recovers the meereen$ machine account NT hash offline via precomputed DES rainbow tables (NetNTLMv1's DES-based response over a known challenge is fully reversible this way, not a brute-force crack). The most universal NTLMv1 avenue: independent of relay viability, LDAP signing, channel binding, ADCS, or DC count. A successful offline crack yields the machine account's credential. This step was identified from the environment's configuration and was not exercised during this engagement.

REMEDIATION

- Disable NTLMv1 (LmCompatibilityLevel >= 3) across the estate via GPO
- Remove or harden authentication-coercion vectors (PrinterBug, PetitPotam, DFSCoerce)
- Note that LDAP signing / channel binding do NOT mitigate the offline crack: only NTLMv1 removal does
- Monitor for NTLMv1 authentication (Event ID 4624, package NTLM V1) and coercion-induced auth (4768/4769)

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: meereen$ is a member of Domain Controllers and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these attack paths.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

VERIFY THIS FINDING INDEPENDENTLY

WINDOWS / SYSADMIN

```
Confirm Domain Controllers holds the two replication rights on the domain head that make DCSync possible (GUIDs 1131f6aa-
and 1131f6ad-):
$dn = (Get-ADDomain).DistinguishedName
(Get-Acl "AD:$dn").Access |
  Where-Object { $_.IdentityReference -like '*Domain Controllers*' -and $_.ObjectType -in '1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2','1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' } |
  Select-Object IdentityReference, ActiveDirectoryRights, ObjectType
```

LINUX / PENTESTER

```
Read the domain object's DACL and confirm Domain Controllers has the Get-Changes / Get-Changes-All rights (read-only):
bloodyAD --host <dc_ip> -d essos.local -u <user> -p <pass> get object DC=essos,DC=local --attr nTSecurityDescriptor --
resolve-sd
# Reference: https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync
```

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these attack paths.

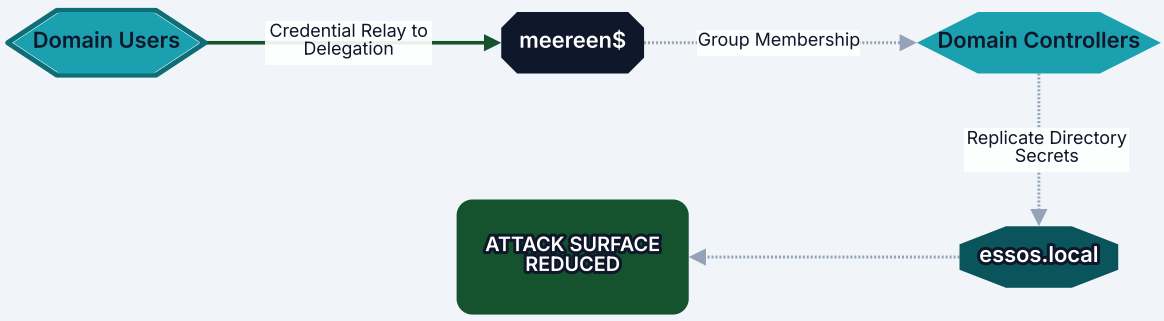
2 technique steps across a 3-hop chain (1 hop is structural group membership).

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Domain Users → ATTACK SURFACE REDUCED HARDENING OBSERVED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Credential Relay to Delegation, Group Membership, and Replicate Directory Secrets. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. **CREDENTIAL RELAY TO DELEGATION (NTLMV1 RELAY → RBCD)** THEORETICAL

   NTLMv1 Relay → RBCD: Domain Users coerces meereen$ to authenticate, relays that NTLMv1 authentication to a domain controller, writes resource-based constrained delegation, and obtains local administrator access on meereen$ via S4U. A successful relay grants local administrator access on the target host. Attack surface reduced: single DC, self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

2. **GROUP MEMBERSHIP (MEMBEROF)** STRUCTURAL

   Group membership: meereen$ is a member of Domain Controllers and inherits its privileges.

3. **REPLICATE DIRECTORY SECRETS (DCSYNC)** THEORETICAL

   DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

2 technique steps across a 3-hop chain (1 hop is structural group membership).

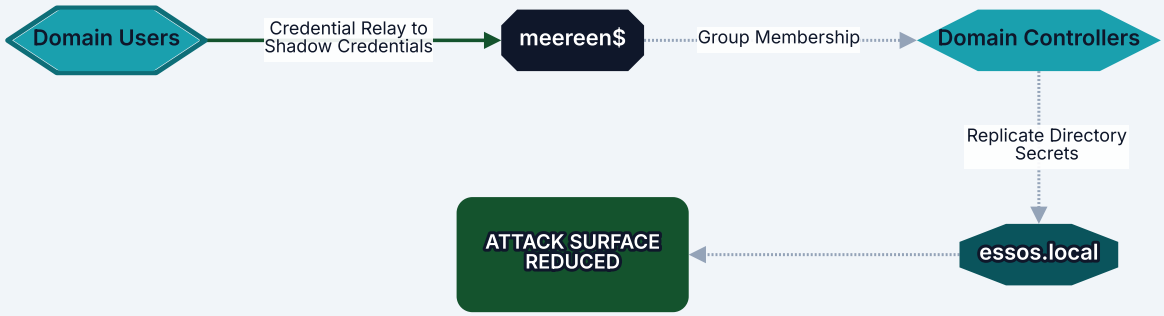
○ **ATTACK SURFACE REDUCED**

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

Domain Users → ATTACK SURFACE REDUCED

HARDENING OBSERVED

Starting from Domain Users, an attacker can reach essos.local in 3 steps. The path chains Credential Relay to Shadow Credentials, Group Membership, and Replicate Directory Secrets. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. **CREDENTIAL RELAY TO SHADOW CREDENTIALS (NTLMV1 RELAY → SHADOW CREDENTIALS)** THEORETICAL

   NTLMv1 Relay → Shadow Credentials: Domain Users coerces meereen$, relays its NTLMv1 authentication to a domain controller, writes a key credential, and recovers the meereen$ machine account NT hash via PKINIT. A successful relay yields the target computer account's own credential. Attack surface reduced: single DC, self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

2. **GROUP MEMBERSHIP (MEMBEROF)** STRUCTURAL

   Group membership: meereen$ is a member of Domain Controllers and inherits its privileges.

3. **REPLICATE DIRECTORY SECRETS (DCSYNC)** THEORETICAL

DCSync: Domain Controllers can replicate secrets from the domain and extract the krbtgt hash.

2 technique steps across a 3-hop chain (1 hop is structural group membership).

○ ATTACK SURFACE REDUCED

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

03 Technical Findings

Detailed vulnerability breakdown with remediation guidance.

ADSCAN SCORING METHODOLOGY

Three categories, and only one of the scores is CVSS.

Each finding is classified into one of three categories, visible as a coloured badge, so the reader can separate *what kind of finding it is* from *how severe*: • VULNERABILITY is a real exploit; • CHAIN PREREQUISITE is a primitive that enables an attack chain (Critical only when the chain is confirmed); • POSTURE documents the absence of a control (hygiene gap, capped at High even on Tier-0).

Every finding leads with its **ADscan Priority**: our own severity model, which weighs the technique against what this assessment observed in your directory, the conditions below. It is the coloured chip beside each title and the number the remediation roadmap and the compliance mapping rank by. A smaller reference line carries the finding's baseline classification, which is the same in every environment and is what the counts in this report are grouped by. The two can disagree: a technique classified High can carry a Critical priority here, because this directory supplies the conditions it needs. Where they disagree, the priority is the one to plan from.

A **CVSS Base** score appears in addition wherever the finding maps to a published CVSS v3.1 Base vector. The vector is printed beside it, so the score can be recomputed on the FIRST calculator. Most Active Directory exposures (a misconfigured certificate template, a readable LAPS attribute, a control that is simply absent) have no such vector; those findings show the ADscan Priority alone rather than a number dressed up as a standard.

`Tier-0 exposure`: affected principal or attack-path target is Domain Admin / KRBTGT / DC. `DC targeting`: at least one Domain Controller is in scope of the issue.

`Relay confirmed`: a vulnerable relay target (ADCS Web Enrollment without EPA, LDAP without signing/CB) was identified in this workspace.

`Exploitation confirmed`: concrete evidence captured (cracked hash, working PoC, full chain executed).

F-001

ADCS ESC1 - Misconfigured Certificate Template

PRIORITY 9.9

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.9 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC1 abuse confirmed: certificate enrollment with attacker-supplied SAN succeeded

DESCRIPTION

ADCS ESC1 occurs when a certificate template is configured to allow requesters to specify a Subject Alternative Name (SAN) in their certificate request, combined with an authentication-capable Extended Key Usage (EKU) such as Client Authentication, Smart Card Logon, or PKINIT. Any principal with enroll permissions on such a template can request a certificate asserting the identity of any user in the domain, including Domain Administrators, by specifying their UPN in the SAN field. Active Directory validates Kerberos authentication based on the certificate SAN rather than the requesting identity, allowing the attacker to obtain a TGT for the impersonated user without knowledge of their password.

IMPACT

Any domain user with enrollment rights on the template can obtain a certificate impersonating a Domain Administrator and authenticate to any Kerberos-capable service with full DA privileges. The resulting access bypasses password rotation, MFA tied to passwords, and most authentication monitoring, as the action uses a legitimately issued certificate. In this environment, affected template: ESC1 (Domain Users can enrol).

AFFECTED ASSETS

- `Template: ESC1`
- `Domain Users` *enrollee*

RECOMMENDED FIX

Stop the template from honouring a requester-supplied SAN (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC1 - Misconfigured Certificate Template” in the **`AD Hardening Playbook`**.

F-002

noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

PRIORITY 9.8

Baseline severity Critical CVE • VULNERABILITY

CWE-290 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

NoPac chains two Active Directory vulnerabilities to achieve domain compromise from any standard domain user account. CVE-2021-42278 permits creating machine accounts with a sAMAccountName that does not end in the required dollar sign ($), meaning the account name can be set to match a Domain Controller's name exactly (e.g. 'DC01' instead of the legitimate 'DC01$'). CVE-2021-42287 exploits a Kerberos PAC validation bug: when a service ticket is requested for a principal that no longer exists, the KDC falls back to searching with a trailing '$' appended. An attacker exploits this combination by creating a machine account named 'DC01', requesting a TGT for it, renaming the account back to its original name so 'DC01' no longer exists, and then requesting a service ticket for 'DC01'. The KDC falls back to 'DC01$', finds the legitimate Domain Controller, and issues a service ticket with DC-level privileges. The resulting ticket can be used for a full DCSync.

IMPACT

Any domain user can escalate to Domain Controller-level privileges within minutes and perform a full DCSync to extract every domain credential including KRBTGT. The attack requires only default permissions (ms-DS-MachineAccountQuota > 0, the default value is 10) and produces a Domain Admin-equivalent Kerberos ticket without interacting with any privileged account. The low barrier makes this exploitable by any attacker with a single valid domain credential. In this environment, affected host: meereen.essos.local (192.168.180.12).

AFFECTED ASSETS

- `meereen.essos.local (192.168.180.12)` *vulnerable-host*

RECOMMENDED FIX

Patch all Domain Controllers (the only complete fix) (+1 alternative)

> Full step-by-step runbook, commands and validation: see “noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)” in the **AD Hardening Playbook**.

F-003

ADCS ESC9 - No Security Extension on Certificate Template

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC9 template lacks security extension on Tier-0-relevant authentication path

DESCRIPTION

ADCS ESC9 exploits the CT_FLAG_NO_SECURITY_EXTENSION flag on a certificate template. When this flag is set, the szOID_NTDS_CA_SECURITY_EXT extension (which embeds the requester's SID into the issued certificate) is omitted. Without this SID binding, certificate-to-account mapping relies on UPN matching rather than strong SID-based identity verification. An attacker with GenericWrite access to an account that can enroll in the affected template can modify that account's UPN to match a high-privilege target (e.g., a Domain Admin UPN), obtain a certificate during that window, restore the UPN, and then use the issued certificate to authenticate as the target user. This technique bypasses the KB5014754 strong mapping protections when the security extension is absent.

IMPACT

Attackers can impersonate arbitrary domain users by temporarily manipulating UPN attributes on controllable accounts. The absence of the security extension means certificates cannot be reliably bound to their true issuance context, enabling persistent authentication bypass for accounts with enrollment access. In this environment, affected template: ESC9 (Spys, Account Operators, khal.drogo (+2 more) can enrol).

AFFECTED ASSETS

- `Template: ESC9`
- `Account Operators` *enrollee*
- `khal.drogo` *enrollee*
- `missandei` *enrollee*
- `Spys` *enrollee*
- `viserys.targaryen` *enrollee*

RECOMMENDED FIX

Remove CT_FLAG_NO_SECURITY_EXTENSION so the SID security extension is embedded (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC9 - No Security Extension on Certificate Template” in the **`AD Hardening Playbook`**.

F-004

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

PRIORITY 9.0

Baseline severity Critical ADCS ● VULNERABILITY

CWE-290 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC14 explicit mapping weakness affects Tier-0 authentication

DESCRIPTION

ADCS ESC14 abuses weak explicit certificate mappings configured through the altSecurityIdentities attribute. When administrators or applications rely on explicit mappings that are not strongly bound to the certificate holder's SID, an attacker who can enroll or obtain a suitable certificate can craft a cert that matches the weak mapping format and authenticate as the mapped account. This bypasses the intended identity binding guarantees of certificate-based authentication and can expose privileged accounts if they are explicitly mapped.

IMPACT

A weak explicit mapping can turn certificate enrollment or certificate theft into immediate privileged impersonation. If the mapped account is an admin, the attacker can authenticate directly as that identity and operate with the same rights as the victim without knowing the victim's password.

AFFECTED ASSETS

- `Template: KerberosAuthentication` *vulnerable-template*
- `Enterprise Read-only Domain Controllers` *holder*

RECOMMENDED FIX

Remove weak altSecurityIdentities explicit mappings (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC14 - Weak Explicit Certificate Mapping Abuse” in the **AD Hardening Playbook**.

F-005

ADCS ESC2 - Any Purpose Certificate Template

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC2 'Any Purpose' template usable for Tier-0 client authentication

DESCRIPTION

ADCS ESC2 occurs when a certificate template is configured with the Any Purpose EKU or with no EKU at all. A certificate with Any Purpose EKU is valid for all certificate usages including client authentication, code signing, server authentication, and email encryption. Combined with low-privilege enrollment rights, this allows an attacker to obtain a certificate that can be used to authenticate as the enrolling user against any Kerberos-capable service. Unlike ESC1, the certificate is issued with the requester's own identity, but the Any Purpose EKU makes the resulting certificate a powerful credential for lateral movement and service access that typically bypasses certificate-based access controls.

IMPACT

Attackers can obtain a maximally privileged certificate with their own identity that can be used for authentication, code signing, and other sensitive operations. Combined with ESC3 (enrollment agent), an ESC2 certificate can be used to request certificates on behalf of other users, effectively bridging to ESC1-class exploitation. In this environment, affected template: ESC2 (Domain Users can enrol).

AFFECTED ASSETS

- `Template: ESC2`
- `Domain Users` *enrollee*

RECOMMENDED FIX

Replace the Any Purpose / no-EKU configuration with scoped EKUs (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC2 - Any Purpose Certificate Template” in the **`AD Hardening Playbook`**.

F-006

ADCS ESC3 - Enrollment Agent Template Abuse

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC3 enrollment-agent template enables Tier-0 enrollment-on-behalf-of

DESCRIPTION

ADCS ESC3 exploits the Certificate Request Agent EKU, which enables a principal to request certificates on behalf of other users. When a template with the Certificate Request Agent EKU is accessible to low-privilege users, an attacker can enroll to obtain an enrollment agent certificate. Using this agent certificate, the attacker can then request certificates on behalf of any domain user (including Domain Administrators) against a second template that permits agent enrollment. This two-step abuse chain allows complete identity impersonation without requiring knowledge of the target user's credentials or any direct interaction with them.

IMPACT

An attacker can impersonate any domain user, including Domain Administrators, through a legitimate two-stage certificate issuance chain. The resulting certificate provides full authentication capability as the impersonated user against all Kerberos-enabled services in the domain. In this environment, affected template: ESC3-CRA (Domain Users can enrol).

AFFECTED ASSETS

- `Template: ESC3-CRA`
- `Domain Users` *enrollee*

RECOMMENDED FIX

Restrict the enrollment-agent template and enforce Enrollment Agent Restrictions on the CA (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC3 - Enrollment Agent Template Abuse” in the **`AD Hardening Playbook`**.

F-007

ADCS ESC8 - NTLM Relay to Web Enrollment

PRIORITY 9.0

Baseline severity High ADCS • VULNERABILITY

CWE-306 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity High in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC8 provides a Tier-0 certificate abuse path

DESCRIPTION

ADCS ESC8 exploits the HTTP-based Certificate Enrollment web interface (certsrv) when NTLM authentication is permitted on the endpoint. An attacker who can coerce outbound NTLM authentication from a privileged host (such as a Domain Controller) via an authentication-coercion trigger (for example a printer-bug or EFSRPC trigger) can relay that authentication to the CA web enrollment interface. The relayed NTLM session authenticates as the coerced host's machine account and requests a Domain Controller certificate. This DC certificate can then be used in a Pass-the-Certificate attack to request a Kerberos TGT as the DC machine account, enabling DCSync and full domain credential extraction.

IMPACT

Successful ESC8 exploitation against a Domain Controller certificate template enables full domain compromise through a DCSync attack, without requiring any initial privileged access. The attack chain (coerce DC authentication, relay to web enrollment, obtain DC certificate, DCSync) can be executed in minutes from a standard domain user account. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- `CA: ESSOS-CA`

RECOMMENDED FIX

Enable Extended Protection for Authentication (EPA) and require HTTPS on the enrollment endpoints (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC8 - NTLM Relay to Web Enrollment” in the **`AD Hardening Playbook`**.

F-008

ADCS ESC5 - Vulnerable CA Object ACL

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC5 PKI ACL exposure affects Tier-0 trust

DESCRIPTION

ADCS ESC5 involves misconfigured access controls on CA-level objects in Active Directory beyond certificate templates, including the CA server computer object, the CA object in the NTAuthCertificates store, the Enrollment Services container, and RPC/DCOM interfaces. When non-privileged principals hold write access to these objects, they can manipulate the CA infrastructure itself. Attacks may include modifying the CA computer object to enable RBCD-based impersonation, altering the NTAuthCertificates store, or exploiting delegated CA management permissions to issue fraudulent certificates directly.

IMPACT

Compromise of CA-level objects can undermine the entire PKI trust infrastructure for the domain. An attacker may be able to issue certificates for arbitrary identities, modify CA policy, or compromise the CA server itself, resulting in complete and persistent domain compromise that survives standard remediation procedures. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23)` *holder*
- `CA: ESSOS-CA`

RECOMMENDED FIX

Lock down ACLs on CA infrastructure objects (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC5 - Vulnerable CA Object ACL” in the **AD Hardening Playbook**.

F-009

ADCS ESC7 - Certificate Authority Privilege Abuse

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC7 CA management rights enable Tier-0 certificate issuance

DESCRIPTION

ADCS ESC7 occurs when non-privileged users hold the Manage CA or Manage Certificates permissions on a Certificate Authority. The Manage CA right grants control over CA configuration and security settings, including the ability to enable the EDITF_ATTRIBUTESUBJECTALTNAME2 flag (ESC6), modify CA ACLs, and add certificate officers. The Manage Certificates right allows approval of pending certificate requests, including those that were submitted with a fraudulent SAN. An attacker with Manage Certificates can submit a certificate request for a privileged user's identity, set it to a pending state requiring approval, and then approve it themselves using their own management permission.

IMPACT

CA management rights provide near-complete control over the PKI trust infrastructure. An attacker can issue certificates for Domain Admins, modify CA policy to introduce persistent vulnerabilities, or manipulate certificate lifecycle in ways that enable persistent authentication bypass across the domain. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23)` *holder*
- `CA: ESSOS-CA`

RECOMMENDED FIX

Remove Manage CA / Manage Certificates from non-PKI principals and enforce separation of duties (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC7 - Certificate Authority Privilege Abuse” in the **AD Hardening Playbook**.

F-010

ADCS ESC4 - Vulnerable Certificate Template ACL

PRIORITY 9.0

Baseline severity Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity Critical in isolation. In this directory the finding carries ADscan Priority 9.0 (Critical), the figure to plan from.

ADSCAN ANALYSIS

ESC4 template ACL grants modification rights affecting Tier-0 enrollment

DESCRIPTION

ADCS ESC4 occurs when non-privileged principals hold write permissions (WriteProperty, WriteDACL, WriteOwner, or GenericWrite) on a certificate template object in Active Directory. Certificate template objects are stored in the Configuration naming context and are subject to standard AD ACL controls. With template modification rights, an attacker can alter the template configuration to introduce ESC1-class vulnerabilities (enabling SAN specification, removing EKU restrictions, or disabling manager approval), obtain a fraudulent certificate, and then optionally revert the changes to avoid detection. This technique escalates an otherwise safe template into an exploitable one without leaving persistent misconfiguration evidence.

IMPACT

An attacker with write access to any template can temporarily transform it into an ESC1-exploitable template, obtain a certificate impersonating a Domain Administrator, then revert the change. The window of exploitation is brief and may not trigger template misconfiguration monitoring, making this a stealthy path to domain compromise. In this environment, affected template: ESC4 (khal.drogo can enrol).

AFFECTED ASSETS

- `Template: ESC4`
- `khal.drogo` *holder*

RECOMMENDED FIX

Remove dangerous write ACEs from the template object (+1 alternative)

> Full step-by-step runbook, commands and validation: see “ADCS ESC4 - Vulnerable Certificate Template ACL” in the **`AD Hardening Playbook`**.

F-011

LAPS Password Readable by Non-Admins

PRIORITY 8.8

Baseline severity High CVSS Base 6.5 LAPS • VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`

Baseline severity High in isolation. In this directory the finding carries ADscan Priority 8.8 (High), the figure to plan from.

ADSCAN ANALYSIS

LAPS attributes readable for Tier-0 assets: privileged local admin credential exposure

DESCRIPTION

The Local Administrator Password Solution (LAPS) stores per-machine local administrator credentials in the ms-Mcs-AdmPwd attribute of computer objects in Active Directory. By design, only designated administrative groups should have read access to this attribute. When the ACL on computer objects grants read access to non-privileged accounts, such as broad user groups, domain users, or helpdesk tiers, any member of those groups can query the attribute and retrieve the current plaintext local administrator password for any LAPS-managed machine. This misconfiguration is commonly introduced during LAPS deployment when access delegation is overly permissive.

IMPACT

Non-privileged users can retrieve local administrator passwords for any LAPS-managed machine in the affected OUs. This enables lateral movement to those machines with full local administrative rights, bypassing the security benefit that LAPS was deployed to provide. In environments where local administrator accounts have network access, this can escalate rapidly. In this environment, the local administrator password is readable on computer braavos.essos.local (192.168.180.23) by Spys and jorah.mormont.

AFFECTED ASSETS

- `Spys → braavos.essos.local (192.168.180.23)`
- `jorah.mormont → braavos.essos.local (192.168.180.23)`

RECOMMENDED FIX

Remove non-admin read access to the LAPS password attribute and rotate (+1 alternative)

> Full step-by-step runbook, commands and validation: see “LAPS Password Readable by Non-Admins” in the **AD Hardening Playbook**.

F-012

PrintNightmare Vulnerable Hosts Detected

PRIORITY 8.8

Baseline severity High CVSS Base 8.8 CVE • VULNERABILITY

CWE-269 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

DESCRIPTION

PrintNightmare (CVE-2021-34527) is a critical vulnerability in the Windows Print Spooler service that allows authenticated users to load arbitrary DLLs through the AddPrinterDriverEx() RPC call by specifying a UNC path to a malicious driver package. The vulnerability exists in both a remote variant (RCE via network RPC) and a local variant (LPE via local named pipe). Remote exploitation is possible when the Print Spooler service accepts remote client connections, which is common on servers that act as print servers. The service runs as SYSTEM, meaning any loaded DLL executes with the highest privilege level on the host.

IMPACT

An authenticated domain user can remotely execute arbitrary code as SYSTEM on any vulnerable host where the Print Spooler accepts remote connections. When the affected host is a Domain Controller, this results in immediate domain-level compromise. The low authentication bar (any valid domain account) makes this vulnerability high-severity in any Active Directory environment where Print Spooler is running on critical systems. In this environment, affected hosts: meereen.essos.local (192.168.180.12) and braavos.essos.local (192.168.180.23).

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23)` *vulnerable-host*
- `meereen.essos.local (192.168.180.12)` *vulnerable-host*

RECOMMENDED FIX

Patch and disable the Print Spooler where unused (+1 alternative)

> Full step-by-step runbook, commands and validation: see “PrintNightmare Vulnerable Hosts Detected” in the **AD Hardening Playbook**.

F-013

Domain Controller Accepts NTLMv1 Authentication

PRIORITY 8.5

Baseline severity High AUTHENTICATION • CHAIN PREREQUISITE

CWE-327 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

Baseline severity High in isolation. In this directory the finding carries ADscan Priority 8.5 (High), the figure to plan from.

ADSCAN ANALYSIS

NTLMv1 accepted by Domain Controllers: challenge/response is trivially crackable

DESCRIPTION

If the Domain Controller authenticates back using NTLMv1 during a coerced callback, the environment still permits a legacy NTLM mode with materially weaker cryptographic protections. NTLMv1 is significantly easier to relay, crack, and abuse than NTLMv2 and should be treated as deprecated in enterprise Active Directory.

IMPACT

NTLMv1 acceptance weakens the authentication posture of the domain and increases the chance that coerced or intercepted authentication can be replayed against another service or cracked offline. Where present on Domain Controllers, the resulting exposure affects the most sensitive authentication boundary in the environment. In this environment, affected host: meereen.essos.local (192.168.180.12).

AFFECTED ASSETS

- `meereen.essos.local (192.168.180.12)`

RECOMMENDED FIX

Refuse LM and NTLMv1 domain-wide (LmCompatibilityLevel 5) (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Domain Controller Accepts NTLMv1 Authentication” in the **AD Hardening Playbook**.

F-014

gMSA Password Readable by Non-Admins

PRIORITY 7.5

Baseline severity High CVSS Base 6.5 GMSA • VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

DESCRIPTION

Group Managed Service Accounts (gMSA) are a special account type in Active Directory that provides automatic password management for service accounts. The password is stored in the msDS-ManagedPassword attribute of the gMSA object and is only readable by principals listed in the msDS-GroupMSAMembership attribute. When this access control list is misconfigured to include non-privileged groups or overly broad membership, any member can retrieve the gMSA password blob using the DSGetPassword API. The password is returned as an MSDS-MANAGEDPASSWORD_BLOB structure that can be parsed to extract the current NT hash, enabling Pass-the-Hash attacks or Kerberos ticket requests using the gMSA's identity.

IMPACT

Compromise of a gMSA password provides full impersonation of the service account, including all associated service permissions, SPN-based access, and any delegated rights. Service accounts typically have privileged access to databases, web services, backup systems, and other critical infrastructure, making this a high-impact finding depending on the gMSA's configured permissions. In this environment, the managed-service-account password is readable for account gmsaDragon$ by braavos.essos.local (192.168.180.23).

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23) → gmsaDragon$`

RECOMMENDED FIX

Restrict msDS-GroupMSAMembership to the hosts that run the service (+1 alternative)

> Full step-by-step runbook, commands and validation: see “gMSA Password Readable by Non-Admins” in the **AD Hardening Playbook**.

F-015

SMBv1 Protocol Enabled

PRIORITY 7.5

Baseline severity High NETWORK SECURITY • VULNERABILITY

CWE-1104 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

One or more hosts respond to SMBv1 (NT LM 0.12) negotiate requests. SMBv1 is a legacy protocol deprecated by Microsoft since 2014. It lacks modern security features (encryption, secure negotiate, pre-auth integrity) and is directly exploited by EternalBlue (MS17-010), EternalRomance, and related NSA-derived tools that enabled WannaCry and NotPetya ransomware. Microsoft has disabled SMBv1 by default since Windows 10 1709.

IMPACT

Hosts with SMBv1 enabled are vulnerable to EternalBlue (MS17-010) and related exploits if unpatched, and remain exposed to SMBv1-specific attack primitives (NTLM downgrade, signing bypass) regardless of patch status. Domain Controllers with SMBv1 represent a critical exposure.

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23)`
- `meereen.essos.local (192.168.180.12)`

RECOMMENDED FIX

Disable SMBv1 server and client across the estate (+1 alternative)

> Full step-by-step runbook, commands and validation: see “SMBv1 Protocol Enabled” in the **AD Hardening Playbook**.

F-016

AS-REP Roasting

PRIORITY 6.9

Baseline severity Medium CVSS Base 5.3 KERBEROS • VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

Preauthentication offers protection against offline Password Cracking. When enabled, a user requesting access to a resource initiates communication with the Domain Controller (DC) by sending an Authentication Server Request (AS-REQ) message with a timestamp that is encrypted with the hash of their password. If and only if the DC is able to successfully decrypt the timestamp with the hash of the user's password, it will then send an Authentication Server Response (AS-REP) message that contains the Ticket Granting Ticket (TGT) to the user. Part of the AS-REP message is signed with the user's password. For each account found without preauthentication, an adversary may send an AS-REQ message without the encrypted timestamp and receive an AS-REP message with TGT data which may be encrypted with an insecure algorithm such as RC4. The recovered encrypted data may be vulnerable to offline Password Cracking attacks similarly to Kerberoasting and expose plaintext credentials.

IMPACT

A successful AS-REP Roasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain. In this environment, affected account: missandei.

AFFECTED ASSETS

- `missandei` EXPOSED *asrep-roastable-target*

RECOMMENDED FIX

Re-enable Kerberos pre-authentication on affected accounts (+1 alternative)

> Full step-by-step runbook, commands and validation: see “AS-REP Roasting” in the **AD Hardening Playbook**.

F-017

Kerberoasting

PRIORITY 5.3

Baseline severity Medium CVSS Base 4.3 KERBEROS • VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

In an Active Directory (AD) environment, Service Principal Names (SPNs) are used to uniquely identify instances of a Windows service. Kerberos authentication requires that each SPN be associated with one service account (Active Directory user account). Any authenticated AD user can request one or more Kerberos Ticket-Granting Service (TGS) tickets from the domain controller for any SPN accounts. These tickets are encrypted with the associated AD account's NTLM password hash. They can be brute forced offline with GPU-accelerated password cracking if a weak password is used along with the RC4 encryption algorithm. If AES encryption is in use, it will take more resources to crack a ticket to reveal the account's clear-text password, but it is possible if weak passwords are in use.

IMPACT

A successful Kerberoasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain. In this environment, affected account: sql_svc.

AFFECTED ASSETS

- sql_svc EXPOSED *roastable-target*

RECOMMENDED FIX

Migrate the SPN to a Group Managed Service Account (gMSA) (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Kerberoasting” in the **AD Hardening Playbook**.

F-018

Weak Default Domain Password Policy

PRIORITY 5.3

Baseline severity Medium DOMAIN CONFIGURATION • VULNERABILITY

CWE-521 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

The Default Domain Password Policy fails one or more of the industry-standard controls (CIS Microsoft Windows Server Benchmark, Microsoft Security Baseline, DISA STIG): account lockout threshold, minimum password length, or the complexity requirement. Each loose control reduces the cost of credential-based attacks against the domain. Together they make password spraying, offline cracking, and low-entropy guessing trivially viable for any unprivileged principal that reaches authentication endpoints (LDAP, Kerberos, SMB, OWA, RDP, VPN front-doors).

IMPACT

Combined sub-issues compound attacker capability: account lockout disabled removes the natural ceiling on spray attempts; short minimum length brings passwords into consumer-GPU password-cracking reach (sub-8 chars: minutes per hash; 8-13 chars with dictionaries+rules: hours to days); complexity disabled allows trivially-structured passwords (seasons, company name + year, default keyboard patterns) that exhaust within the first few hundred spray candidates. Any single sub-issue raises the risk; their combination predicts initial-access compromise within a typical engagement window.

AFFECTED ASSETS

- `essos.local`

OBSERVED VS RECOMMENDED

SETTING	OBSERVED	RECOMMENDED	SOURCE
min pwd length	5	⩾ 14	CIS Microsoft Windows Server Benchmark (L1)
complexity enabled	False	== True	Microsoft Security Baseline
pwd history length	24	⩾ 24	CIS Microsoft Windows Server Benchmark
lockout threshold	5	⩽ 5	CIS Microsoft Windows Server Benchmark
max pwd age days	Never expires (set to 37,201 days)	⩽ 365	Microsoft Security Baseline

RECOMMENDED FIX

Harden the Default Domain Password Policy to the CIS / Microsoft baseline (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Weak Default Domain Password Policy” in the **AD Hardening Playbook**.

F-019

SMB Signing Not Required

PRIORITY 5.0

Baseline severity Medium NETWORK SECURITY • POSTURE

CWE-300 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

One or more domain-joined computers do not require SMB packet signing. When SMB signing is not enforced, an attacker in a man-in-the-middle position can relay NTLM authentication from these hosts to other services, authenticate as the relayed identity, and potentially execute code or access resources without knowing the credential.

IMPACT

Hosts with SMB signing disabled are viable relay targets. If the relayed credential belongs to a Domain Admin or computer account with unconstrained delegation, a single intercepted authentication can lead to full domain compromise. Domain Controllers with signing disabled are particularly severe as they represent the highest-value relay target in the environment.

AFFECTED ASSETS

- `braavos.essos.local (192.168.180.23)`

RECOMMENDED FIX

Require SMB signing on both server and client via GPO (+1 alternative)

> Full step-by-step runbook, commands and validation: see “SMB Signing Not Required” in the **AD Hardening Playbook**.

F-020

Accounts with Non-Expiring Passwords

PRIORITY 3.7

Baseline severity Low POLICY • POSTURE

CWE-521 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

Accounts configured with the DONT_EXPIRE_PASSWORD flag are exempt from the domain's password expiration policy, meaning their credentials remain valid indefinitely unless manually changed. While this configuration is sometimes necessary for service accounts running as specific identities, it is frequently applied broadly to user accounts for convenience, or inherited from legacy configurations. Long-lived credentials are statistically more likely to have been exposed through phishing, credential dumping incidents, data breaches, or pass-the-hash attacks that were not detected at the time. An attacker in possession of a non-expiring credential retains access indefinitely unless the compromise is specifically identified and the password is manually rotated.

IMPACT

Compromised non-expiring credentials provide persistent access with no natural remediation deadline. In environments where password rotation is the primary credential invalidation mechanism, these accounts create permanent persistence opportunities for attackers who have obtained the credentials through any means.

AFFECTED ASSETS

- `Administrator`
- `sql_svc`
- `adscan`
- `daenerys.targaryen`
- `drogon`
- `jorah.mormont`
- `khal.drogo`
- `missandei`
- `viserys.targaryen`

RECOMMENDED FIX

Remove DONT_EXPIRE_PASSWORD from standard accounts (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Accounts with Non-Expiring Passwords” in the **`AD Hardening Playbook`**.

F-021

Machine Account Quota Allows Domain Join

PRIORITY 3.5

Baseline severity Low DOMAIN CONFIGURATION • POSTURE

CWE-284 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

The ms-DS-MachineAccountQuota attribute is set to a value greater than 0. This allows any authenticated domain user to join computers to the domain up to the configured limit, which can be abused for RBCD attacks, DNS poisoning via fake computer objects, or Kerberos relay attack preparation.

IMPACT

An attacker with any valid domain credential can create computer objects under their control, enabling Resource-Based Constrained Delegation (RBCD) attacks, Kerberos relay setups (e.g. noPac), and persistence via machine accounts.

AFFECTED ASSETS

- `essos.local`

RECOMMENDED FIX

Set ms-DS-MachineAccountQuota to 0 (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Machine Account Quota Allows Domain Join” in the **`AD Hardening Playbook`**.

F-022

Passwords Predating Current Policy

PRIORITY 3.5

Baseline severity Low IDENTITY HYGIENE • POSTURE

CWE-521 essos.local

METHODOLOGY *Scored by the ADscan Priority model: no published CVSS Base vector applies to this finding.*

DESCRIPTION

One or more enabled user accounts have a password that was last set before the most recent modification to the applicable password policy (Default Domain Policy or a Fine-Grained PSO). The current policy requirements (minimum length, complexity, or maximum age) were not in effect when the credential was created. Active Directory does not retroactively force a reset on policy changes, so these accounts may carry credentials that do not comply with the organisation's current security baseline.

IMPACT

Credentials established under a weaker policy may be shorter, simpler, or older than the current standard allows. Attackers obtaining these hashes through LDAP, Kerberoasting, or credential dumping face a reduced cracking workload. When affected accounts are Tier-0 or high-value identities, the impact escalates to potential domain compromise.

AFFECTED ASSETS

- `Administrator` · Password set 2026-05-01 (~160 days ago)
- `daenerys.targaryen` · Password set 2026-05-01 (~160 days ago)
- `drogon` · Password set 2026-05-01 (~160 days ago)
- `jorah.mormont` · Password set 2026-05-01 (~160 days ago)
- `khal.drogo` · Password set 2026-05-01 (~160 days ago)
- `missandei` · Password set 2026-05-01 (~160 days ago)
- `viserys.targaryen` · Password set 2026-05-01 (~160 days ago)

RECOMMENDED FIX

Force a reset on accounts whose pwdLastSet predates the policy change (+1 alternative)

> Full step-by-step runbook, commands and validation: see “Passwords Predating Current Policy” in the **AD Hardening Playbook**.

Compromised Credentials

Accounts whose credentials were recovered during the assessment, with the method used to obtain each. Secret values are never stored or reproduced in this report; only the credential type is shown. Where an account was reached by more than one technique, every route is listed. Closing one of them leaves the others open.

Domain · essos.local

ACCOUNT	METHOD	ROUTES	CREDENTIAL TYPE
`administrator`	ADCS ESC1 · also via DCSync	2 INDEPENDENT	NT HASH

> 9 ACCOUNTS Every principal in the domain became extractable via DCSync once full domain compromise was achieved (6 Password, 3 NT hash). The complete per-account list is in the machine-readable appendix bundled with this report.

This count includes the krbtgt account key alongside 9 user and service accounts.

Recovered credentials were tested against the ADscan AD Audit Wordlist: 94 million entries, curated and frequency-ordered (most-crackable-first) for Active Directory service and user accounts.

Built on public credential-research corpora (hashmob, kerberoast_pws, kaonashi), deduplicated with order-preserving merge and tuned by ADscan for AD audit workloads. Per-domain targeted candidates are always tested first.

04 MITRE ATT&CK Coverage

Techniques exercised across the identified attack surface.

TECHNIQUE	NAME	LINKED FINDINGS
T1068	**Exploitation for Privilege Escalation**	PrintNightmare Vulnerable Hosts Detected, noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)
T1078	**Valid Accounts**	Accounts with Non-Expiring Passwords, Passwords Predating Current Policy, Domain Controller Accepts NTLMv1 Authentication
T1110.002	**Brute Force: Password Cracking**	Weak Default Domain Password Policy
T1110.003	**Brute Force: Password Spraying**	Weak Default Domain Password Policy
T1210	**Exploitation of Remote Services**	SMBv1 Protocol Enabled
T1555	**Credentials from Password Stores**	LAPS Password Readable by Non-Admins, gMSA Password Readable by Non-Admins
T1557	**Adversary-in-the-Middle**	Domain Controller Accepts NTLMv1 Authentication
T1557.001	**LLMNR/NBT-NS Poisoning and SMB Relay**	SMB Signing Not Required
T1558	**Steal or Forge Kerberos Tickets**	noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)
T1558.003	**Steal or Forge Kerberos Tickets: Kerberoasting**	Kerberoasting
T1558.004	**Steal or Forge Kerberos Tickets: AS-REP Roasting**	AS-REP Roasting
T1649	**Steal or Forge Authentication Certificates**	ADCS ESC9 - No Security Extension on Certificate Template, ADCS ESC14 - Weak Explicit Certificate Mapping Abuse, ADCS ESC1 - Misconfigured Certificate Template, ADCS ESC2 - Any Purpose Certificate Template, ADCS ESC3 - Enrollment Agent Template Abuse, ADCS ESC8 - NTLM Relay to Web Enrollment, ADCS ESC5 - Vulnerable CA Object ACL, ADCS ESC7 - Certificate Authority Privilege Abuse, ADCS ESC4 - Vulnerable Certificate Template ACL

ATT&CK COVERAGE · ENTERPRISE MATRIX

12 techniques observed across 3 tactics

Density mapped to MITRE ATT&CK · darker cells indicate higher finding concentration or more severe exposure.

RECONNAISSANCE	RESOURCE DEVELOPMENT	INITIAL ACCESS	EXECUTION	PERSISTENCE	PRIVILEGE ESCALATION	DEFENSE EVASION	CREDENTIAL ACCESS	DISCOVERY	LATERAL MOVEMENT	COLLECTION	COMMAND AND CONTROL	EXFILTRATION	IMPACT
		T1133		T1098	T1134	T1027	T1003	T1018	T1021.001				T1486
		T1190		T1136	T1068 2	T1070	T1003.001	T1069	T1021.002				
					T1078 3	T1556.007	T1003.006	T1087	T1210 1				
					T1078.002		T1110	T1087.002	T1550.002				
							T1110.001	T1482	T1550.003				
							T1110.002 1		T1570				
							T1110.003 1						
							T1187						
							T1556						
							T1557 1						
							T1552						
							T1552.001						
							T1552.006						
							T1555 2						
							T1557.001 1						
							T1558 1						
							T1558.003 1						
							T1558.004 1						
							T1649 9						

Density none → low → moderate → high

12 techniques · 3 tactics · 22 findings

KILL CHAIN · TEMPORAL NARRATIVE

How the attack chain unfolded

Earliest tactic to most recent · severity-coded · catalog-aligned to MITRE ATT&CK.

PRIVILEGE ESCALATION

T1068	Exploitation for Privilege Escalation		2 findings	CRITICAL
T1078	Valid Accounts		3 findings	HIGH

CREDENTIAL ACCESS

T1558	Steal or Forge Kerberos Tickets		1 finding	CRITICAL
T1649	Steal or Forge Authentication Certificates		9 findings	CRITICAL
T1555	Credentials from Password Stores		2 findings	HIGH
T1557	Adversary-in-the-Middle		1 finding	HIGH
T1110.002	Password Cracking		1 finding	MEDIUM
T1110.003	Password Spraying		1 finding	MEDIUM
T1557.001	LLMNR/NBT-NS Poisoning + SMB Relay		1 finding	MEDIUM
T1558.003	Kerberoasting		1 finding	MEDIUM
T1558.004	AS-REP Roasting		1 finding	MEDIUM

LATERAL MOVEMENT

T1210	Exploitation of Remote Services		1 finding	HIGH

DOMAIN COMPROMISE

DA	Full Domain Compromise Reached	1 of 14 paths walked end to end to full domain compromise		CRITICAL

> *The assessment identified 14 routes to full domain compromise, 1 of which was validated end to end. The kill-chain spans 3 ATT&CK tactics across 12 techniques, with credential access as the primary pivot. Immediate remediation should focus on the techniques flagged below before any compensating control work.*

05 NIS2 Directive

NIS2 obligations affected by Active Directory security findings.

NIS2: Network and Information Security Directive

NIS2 requires effective technical and organisational security measures. AD weaknesses such as privilege escalation, credential exposure, and weak access governance materially affect identity, access control, and incident containment obligations.



4	1	0	5
NON-CONFORMANT	PARTIAL	CONFORMANT	CONTROLS ASSESSED

CERTIFICATION RISK · HIGH

4 major non-conformities identified. Address before the next certification or surveillance audit.

*Conformance of assessed AD-relevant controls only. ADscan evaluates the Active Directory attack surface in scope for this engagement; controls outside that scope are marked **Not assessed** and are excluded from this percentage. This figure is therefore the conformance of what was tested, not an overall framework certification posture.*

OTHER

5 controls · **4** non-conformant · **1** partial · **0** conformant

Non-conformity Summary

Gaps classified by audit severity. Major non-conformities typically trigger corrective action requests (CARs) in certification audits.

MAJOR NON-CONFORMITIES		
21.2.h	Cryptography and encryption	9.9
21.2.i	Human resources security and access control	9.9
21.2.e	Security in network and information systems	9.8
21.2.a	Risk analysis and information system security	7.5

MINOR NON-CONFORMITIES / OBSERVATIONS		
21.2.j	Multi-factor authentication	6.9

Major non-conformities: ADscan Priority ≥ 7.0. Minor non-conformities: ADscan Priority < 7.0 or attack paths only. Classification is indicative; auditor judgment may differ.

Control Assessment

Controls sorted by conformity status. Non-conformant controls carry the highest audit risk. One attack chain often bears on several obligations, so chains are counted against each control they affect and set out in full once, in the attack-path section. Each control counts the chains that bear on

that obligation and still represent open exposure, which is why the figure differs between controls and is stated against the assessment total.

21.2.h

NON-CONFORMANT · MAJOR

Cryptography and encryption

Policies and procedures regarding the use of cryptography and, where appropriate, encryption.

AFFECTED FINDINGS

- ADCS ESC1 - Misconfigured Certificate Template 9.9
- ADCS ESC14 - Weak Explicit Certificate Mapping Abuse 9.0
- ADCS ESC2 - Any Purpose Certificate Template 9.0
- ADCS ESC3 - Enrollment Agent Template Abuse 9.0
- ADCS ESC4 - Vulnerable Certificate Template ACL 9.0
- +8 more

21.2.i

NON-CONFORMANT · MAJOR

Human resources security and access control

Human resources security, access control policies and asset management.

AFFECTED FINDINGS

- ADCS ESC1 - Misconfigured Certificate Template 9.9
- noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287) 9.8
- ADCS ESC2 - Any Purpose Certificate Template 9.0
- ADCS ESC3 - Enrollment Agent Template Abuse 9.0
- ADCS ESC4 - Vulnerable Certificate Template ACL 9.0
- +8 more

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

21.2.e

NON-CONFORMANT · MAJOR

Security in network and information systems

Security in the acquisition, development and maintenance of network and information systems, including vulnerability handling and disclosure.

AFFECTED FINDINGS

- noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287) 9.8
- ADCS ESC8 - NTLM Relay to Web Enrollment 9.0
- PrintNightmare Vulnerable Hosts Detected 8.8
- Domain Controller Accepts NTLMv1 Authentication 8.5
- SMBv1 Protocol Enabled 7.5
- +1 more

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

21.2.a

NON-CONFORMANT · MAJOR

Risk analysis and information system security

Policies on risk analysis and the security of information systems.

AFFECTED FINDINGS

- SMBv1 Protocol Enabled 7.5

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

21.2.j

PARTIALLY CONFORMANT · MINOR

Multi-factor authentication

The use of multi-factor authentication or continuous authentication solutions, secured voice, video and text communications and secured emergency communication ...

AFFECTED FINDINGS

- AS-REP Roasting 6.9
- Kerberoasting 5.3
- Weak Default Domain Password Policy 5.3
- Accounts with Non-Expiring Passwords 3.7
- Passwords Predating Current Policy 3.5

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

06 DORA Compliance

DORA ICT risk management obligations affected by AD security findings.

DORA: Digital Operational Resilience Act

DORA focuses on ICT risk management and operational resilience for financial entities. Active Directory attack paths and identity control gaps indicate where compromise could disrupt critical ICT services and trigger reporting obligations.



7	3	0	10	1
NON-CONFORMANT	PARTIAL	CONFORMANT	CONTROLS ASSESSED	NOT ASSESSED

CERTIFICATION RISK · HIGH

7 major non-conformities identified. Address before the next certification or surveillance audit.

*Conformance of assessed AD-relevant controls only. ADscan evaluates the Active Directory attack surface in scope for this engagement; controls outside that scope are marked **Not assessed** and are excluded from this percentage. This figure is therefore the conformance of what was tested, not an overall framework certification posture.*

ICT RISK MANAGEMENT

7 controls · **4** non-conformant · **2** partial · **0** conformant · **1** not assessed

INCIDENT MANAGEMENT

2 controls · **2** non-conformant · **0** conformant

RESILIENCE & RECOVERY

1 controls · **1** non-conformant · **0** conformant

GOVERNANCE

1 controls · **1** partial · **0** conformant

Non-conformity Summary

Gaps classified by audit severity. Major non-conformities typically trigger corrective action requests (CARs) in certification audits.

MAJOR NON-CONFORMITIES

art_9_4	Protection: identity & MFA	9.9
art_17	ICT-related incident management process	9.9
art_19	Reporting of major ICT-related incidents	9.9

MINOR NON-CONFORMITIES / OBSERVATIONS

art_9_4_b	Protection: network and infrastructure security	5.0
art_5	Governance and organisation	3.7
art_10	Detection	0.0

art_9_2	Protection: access control	9.8
art_9_3	Protection: network security	9.0
art_11	Response and recovery	8.8
art_6	ICT risk management framework	8.5

Major non-conformities: ADscan Priority ≥ 7.0. Minor non-conformities: ADscan Priority < 7.0 or attack paths only. Classification is indicative; auditor judgment may differ.

Control Assessment

Controls sorted by conformity status. Non-conformant controls carry the highest audit risk. One attack chain often bears on several obligations, so chains are counted against each control they affect and set out in full once, in the attack-path section. Each control counts the chains that bear on that obligation and still represent open exposure, which is why the figure differs between controls and is stated against the assessment total.

art_9_4 ICT RISK MANAGEMENT NON-CONFORMANT · MAJOR

Protection: identity & MFA

Financial entities must implement strong authentication mechanisms. Per Art. 9(4) and Commission Delegated Regulation (EU) 2024/1774, this explicitly requires: ...

AFFECTED FINDINGS

- ADCS ESC1 - Misconfigured Certificate Template 9.9
- noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287) 9.8
- ADCS ESC14 - Weak Explicit Certificate Mapping Abuse 9.0
- ADCS ESC2 - Any Purpose Certificate Template 9.0
- ADCS ESC3 - Enrollment Agent Template Abuse 9.0
- +12 more

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_17 INCIDENT MANAGEMENT NON-CONFORMANT · MAJOR

ICT-related incident management process

Financial entities must define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents. This is t...

AFFECTED FINDINGS

- ADCS ESC1 - Misconfigured Certificate Template 9.9
- PrintNightmare Vulnerable Hosts Detected 8.8

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_19 INCIDENT MANAGEMENT NON-CONFORMANT · MAJOR

Reporting of major ICT-related incidents

Financial entities must report major ICT-related incidents to the relevant competent authority. Per Art. 19 and Commission Delegated Regulation (EU) 2025/301, t...

AFFECTED FINDINGS

- ADCS ESC1 - Misconfigured Certificate Template 9.9
- PrintNightmare Vulnerable Hosts Detected 8.8

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_9_2 ICT RISK MANAGEMENT NON-CONFORMANT · MAJOR

Protection: access control

Financial entities must implement access control policies based on least-privilege principles, ensuring that access to systems is granted only as necessary for ...

AFFECTED FINDINGS

- noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287) 9.8
- LAPS Password Readable by Non-Admins 8.8
- gMSA Password Readable by Non-Admins 7.5
- Machine Account Quota Allows Domain Join 3.5

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_9_3 ICT RISK MANAGEMENT NON-CONFORMANT · MAJOR

Protection: network security

Financial entities must have in place security measures against network intrusions and data misuse. This includes network segmentation, perimeter protections, a...

AFFECTED FINDINGS

- ADCS ESC8 - NTLM Relay to Web Enrollment 9.0
- Domain Controller Accepts NTLMv1 Authentication 8.5
- SMBv1 Protocol Enabled 7.5

art_11 RESILIENCE & RECOVERY NON-CONFORMANT · MAJOR

Response and recovery

Financial entities must implement a dedicated ICT business continuity policy that enables rapid response to, and recovery from, major ICT-related incidents. Thi...

AFFECTED FINDINGS

- PrintNightmare Vulnerable Hosts Detected 8.8

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_6 ICT RISK MANAGEMENT NON-CONFORMANT · MAJOR

ICT risk management framework

Financial entities must have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system. The frame...

AFFECTED FINDINGS

- Domain Controller Accepts NTLMv1 Authentication 8.5
- SMBv1 Protocol Enabled 7.5
- AS-REP Roasting 6.9
- Kerberoasting 5.3
- Weak Default Domain Password Policy 5.3
- +3 more

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_9_4_b PARTIALLY CONFORMANT · MINOR

ICT RISK MANAGEMENT

Protection: network and infrastructure security

Financial entities must implement a sound network and infrastructure management using appropriate techniques, methods and protocols. Per Art. 9(4)(b) and Commis...

AFFECTED FINDINGS

- SMB Signing Not Required 5.0

art_5 GOVERNANCE PARTIALLY CONFORMANT · MINOR

Governance and organisation

The management body of the financial entity must define, approve, oversee and be accountable for the implementation of all arrangements related to the ICT risk ...

AFFECTED FINDINGS

- Accounts with Non-Expiring Passwords 3.7

art_10 PARTIALLY CONFORMANT · MINOR

ICT RISK MANAGEMENT

Detection

Financial entities must have mechanisms to promptly detect anomalous activities, including ICT network performance and ICT-related incidents. Detection mechanis...

ATTACK-PATH EVIDENCE

14 of the 17 attack chains identified in this assessment · 1 validated end to end · 10 partially validated · 3 identified by configuration analysis

art_8 ICT RISK MANAGEMENT NOT ASSESSED

Identification

Financial entities must identify, classify and adequately document all ICT supported business functions, roles and responsibilities, information assets and ICT ...

Outside the scope of this AD assessment. Not assessed.

07 Start Here - Fixes That Break the Most Attack Paths

Ranked by proven-executed fixes first, then by how many attack paths each one breaks, with the remediation for each. Work them in this order.

START HERE

Start here: the first 1 action contain key material that left your control during this assessment, and nothing else in this report is effective while they are outstanding. The fixes after them are ordered by how much of your attack surface each one removes. A user's exposure can run through several techniques, so closing one reduces their exposure without necessarily removing it. Full protection needs every technique on a user's paths closed, so work the ranked list.

WHO IS AT STAKE

6 of 6 affected users (100%) sit on an attack path that runs through every fix below, so the order is by how much of your attack surface each one removes.

Each row is one attack technique found across multiple paths. "Order" is the remediation order, ranked by proven execution first and then by how many attack paths each fix breaks; it is not the same as a finding's ADscan Priority severity score in Technical Findings. "Impact" is the attack paths the fix carries (the people at stake are named above); "Remediation" is how to close it. A single fix can close multiple independent attack paths at once, so work the list from the top.

These path-counts overlap heavily: the fixes share terminal chains, so the numbers are not additive. Closing a top item may also cover paths counted below it.

ORDER	FIX	IMPACT	REMEDIATION
1	**Certificate Template Privilege Escalation (ADCS ESC1)** `T1649 · Steal or Forge Authentication Certificates`	Eliminates 1 of 1 validated attack path ADscan executed, and 1 of 17 attack paths in total.	MEDIUM Disable CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT on the certificate template, or restrict enrollment to specific privileged security groups. • Disable 'Enrollee supplies subject' on template ESC1, or require manager approval for enrollment. • Restrict enrollment permissions on ESC1 to authorized identities only. • Apply the KB5014754 enforcement mode on the CA to block weak SAN mapping.
2	**Pre-Authentication-less Credential Theft (ASREPRoasting)** `T1558.004 · Steal or Forge Kerberos Tickets: AS-REP Roasting`	Would eliminate 9 of 17 mapped attack paths ADscan has not yet executed. *Largest single surface reduction; proven fixes are sequenced first.*	LOW Enable Kerberos pre-authentication on all accounts (UF_DONT_REQUIRE_PREAUTH must not be set). • Enable Kerberos pre-authentication for missandei (clear DONT_REQ_PREAUTH in userAccountControl). • Enforce strong passwords on accounts that must keep pre-auth disabled. • Monitor Event ID 4768 with pre-authentication type 0 for anomalous requests.

ORDER	FIX	IMPACT	REMEDIATION
3	**Full Control of the Target Object (GenericAll)** T1098 · Account Manipulation	Would eliminate 5 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM For each affected object listed in the per-path remediation steps and the affected-assets appendix, remove the over-privileged GenericAll ACE. Read the object's ACL with `Get-Acl` or `dsacls`, identify the offending principal's full-control entry, and remove it. Where the principal legitimately needs delegated rights, grant back only the specific scoped rights the delegation requires through the Delegation of Control wizard or a narrowly scoped ACE, never full control. Audit high-value object ACLs on a regular schedule so unnecessary full-control grants do not reappear. The exact object distinguished name and the principal to remove for each finding are given in the per-path remediation steps. • Remove the GenericAll ACE that missandei holds over khal.drogo. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=khal.drogo)'`, list what missandei currently holds on it with `(Get-Acl "AD:\CN=khal.drogo,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*missandei*'`, then delete those entries with `dsacls "CN=khal.drogo,CN=Users,DC=essos,DC=local" /R "ESSOS\missandei"`. Before: the entry reads ActiveDirectoryRights=GenericAll, AccessControlType=Allow. After: the same query returns nothing for that principal. • Grant back only the rights the delegation actually needs, never full control. GenericAll carries password reset, key-credential write (Shadow Credentials), servicePrincipalName write and script-path write in one ACE, so any one of them left in place restores the takeover: which is why narrowing it is the fix and auditing it is not. Use the Delegation of Control wizard, or a scoped ACE such as `dsacls "CN=khal.drogo,CN=Users,DC=essos,DC=local" /G "ESSOS\<helpdeskGroup>:CA;Reset Password"` when password reset is genuinely required. • Confirm no other principal holds equivalent control over the same object: `(Get-Acl "AD:\CN=khal.drogo,CN=Users,DC=essos,DC=local").Access | Where-Object { $_.ActiveDirectoryRights -match 'GenericAll|WriteDacl|WriteOwner' -and $_.AccessControlType -eq 'Allow' }`. Anything returned other than Domain Admins, Enterprise Admins or SYSTEM is the same finding under a different principal.
4	**Certificate Infrastructure Takeover (ADCS ESC5)** T1649 · Steal or Forge Authentication Certificates	Would eliminate 4 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Restrict ACL permissions on CA objects and PKI containers in AD. Remove non-privileged write access to CA configuration objects. • Restrict the ACL on the affected PKI object (Domain Admins) so only Tier-0 PKI administrators hold write access; use dsacls / Set-Acl to revoke GenericAll / GenericWrite / WriteDacl / WriteOwner from every other principal. • Review the NTAuth store with certutil -viewstore -enterprise NTAuth and remove any CA certificate that should not be trusted for domain authentication. • Set the owner of each PKI container (NTAuthStore, Root CA, AIA, Enterprise CA) to a Tier-0 group and treat these objects as part of the identity control plane.
5	**Modify the Target Object (GenericWrite)** T1098 · Account Manipulation	Would eliminate 4 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM For each affected object listed in the per-path remediation steps and the affected-assets appendix, remove the over-privileged GenericWrite ACE. Read the object's ACL with `Get-Acl` or `dsacls`, locate the offending principal's write entry, and remove it. If the principal legitimately needs to write, grant back only the specific attributes the delegation requires with a scoped property-write ACE, not write access across the whole object. Three attributes each hand over the account on their own: msDS-KeyCredentialLink, servicePrincipalName and msDS-AllowedToActOnBehalfOfOtherIdentity. Clear any value already written to those three before removing the ACE, or the takeover survives the fix. The exact object distinguished name and the principal to remove for each finding are given in the per-path remediation steps.

ORDER	FIX	IMPACT	REMEDIATION
			• Remove the GenericWrite ACE that missandei holds on viserys.targaryen. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=viserys.targaryen)'`, list what missandei currently holds on it with `(Get-Acl "AD:\CN=viserys.targaryen,CN=Users,DC=essos,DC=local").Access | Where-Object IdentityReference -like '*missandei*'`, then delete those entries with `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /R "ESSOS\missandei"`. Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal. • Grant back only the specific attributes the delegation needs, rather than write access to the object. GenericWrite is a takeover because three of the attributes it covers each hand over the account on their own: msDS-KeyCredentialLink (a certificate the account can then authenticate with), servicePrincipalName (which exposes the account's password hash to offline cracking), and msDS-AllowedToActOnBehalfOfOtherIdentity (which lets another host impersonate any user to this one). A scoped grant such as `dsacls "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" /G "ESSOS\<group>:WP;description"` gives the delegation its attribute and none of those. • Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on viserys.targaryen: `Get-ADObject "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity`. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with `Set-ADObject "CN=viserys.targaryen,CN=Users,DC=essos,DC=local" -Clear <attribute>`.
6	**Certificate Mapping Abuse (ADCS ESC9)** `T1649 · Steal or Forge Authentication Certificates`	Would eliminate 3 of 17 mapped attack paths ADscan has not yet executed.	HIGH Deploy KB5014754 and set StrongCertificateBindingEnforcement=2 on all DCs. Restrict write access to UPN attributes. Requires thorough testing before full enforcement. • Clear the CT_FLAG_NO_SECURITY_EXTENSION flag on ESC9 so issued certificates carry the szOID_NTDS_CA_SECURITY_EXT SID extension and bind strongly to the enrolling account. • Set StrongCertificateBindingEnforcement to 2 (Full enforcement) on domain controllers per KB5014754 so a certificate without the SID extension is rejected for authentication. • Restrict enrollment on ESC9 and remove it from broad groups so a low-privileged principal cannot request it.
7	**Read the Local Administrator Password (ReadLAPSPassword)** `T1555 · Credentials from Password Stores`	Would eliminate 2 of 17 mapped attack paths ADscan has not yet executed.	LOW Restrict read access on ms-Mcs-AdmPwd (legacy LAPS) or msLAPS-Password (Windows LAPS) to authorized IT admin groups only via AD ACL. • Remove the Control Access ACE on ms-Mcs-AdmPwd / ms-LAPS-Password from jorah.mormont on braavos$. • Audit LDAP reads of ms-LAPS-Password via Event ID 4662 with the LAPS GUID.
8	**Group Membership (MemberOf)**	Would eliminate 2 of 17 mapped attack paths ADscan has not yet executed.	LOW Remove the user/group from the over-privileged group. • Remove viserys.targaryen from Targaryen if the membership is not strictly required: Remove-ADGroupMember -Identity 'Targaryen' -Members 'viserys.targaryen'. • If the membership IS required, scope what Targaryen can reach instead: review every object whose DACL grants rights to Targaryen and tighten the over-broad grant to a named, tier-appropriate group so the inherited attack edge no longer exists.

ORDER	FIX	IMPACT	REMEDIATION
			• Audit group membership periodically (Event ID 4728/4729/4756) and enforce tiering boundaries.
9	**Remote Desktop Access (CanRDP)** T1021.001 · Remote Services: Remote Desktop Protocol	Would eliminate 2 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove the principal from the Remote Desktop Users group on target hosts. Restrict RDP access via GPO and firewall rules. • Review the Remote Desktop Users group on the host and remove principals that do not need interactive access: Invoke-Command -ComputerName meereen.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Remote Desktop Users' }. • Require Network Level Authentication and, for administrative RDP, enable Restricted Admin mode (Set-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Lsa' -Name DisableRestrictedAdmin -Value 0) so credentials are not left recoverable in the session. • Restrict which source hosts may reach TCP 3389 with a host firewall / network segmentation rule so RDP is not exposed broadly across the estate.
10	**Certificate Services Privilege Escalation (ADCS ESC2)** T1649 · Steal or Forge Authentication Certificates	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove Any Purpose EKU or CA issuance rights from the template. Enable CA manager approval for issuance. • Remove the Any Purpose EKU from ESC2 and assign only the specific extended key usages the template legitimately needs; a template used for authentication should carry a restricted EKU set, never Any Purpose or an empty EKU list. • Require CA manager approval (set the CT_FLAG_PEND_ALL_REQUESTS enrollment flag) so a certificate is never issued automatically from this template. • Restrict enrollment permissions on ESC2 to only the identities that must request it, and remove enrollment rights from broad groups such as Domain Users and Authenticated Users.
11	**Certificate Request-Agent Escalation (ADCS ESC3)** T1649 · Steal or Forge Authentication Certificates	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove enrollment agent rights from the template or restrict to a dedicated enrollment agent account with auditing and approval workflow. • Restrict enrollment on the enrollment-agent template ESC3-CRA to a small, explicitly approved set of certificate-management operators; remove enrollment rights from Domain Users and Authenticated Users. • Require CA manager approval on ESC3-CRA so an enrollment-agent certificate is never issued automatically. • On the CA, configure enrollment-agent restrictions (Restricted Enrollment Agents on the Enrollment Agents tab in the CA properties) so an agent certificate can only enroll for a defined set of templates and target principals.
12	**Database Session Access (SQLAccess)** T1078 · Valid Accounts	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove unnecessary SQL login access for the identified principal. Audit Windows-integrated SQL logins and limit who can connect to SQL Server instances.
13	**Certificate Template Takeover (ADCS ESC4)** T1649 · Steal or Forge Authentication Certificates	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove GenericWrite/WriteDACL/WriteOwner permissions from non-privileged principals on the certificate template AD object. • Remove the excessive write rights on ESC4: using dsacls or Set-Acl on the template object, revoke GenericAll / GenericWrite / WriteDacl / WriteOwner from any non-Tier-0 principal so only PKI administrators can modify it. • Set the template owner to a Tier-0 PKI administration group rather than an ordinary user or an over-broad group. • After removing the rights, inspect ESC4 for any ESC1-style changes the attacker may already have applied (enrollee-supplies-subject,

ORDER	FIX	IMPACT	REMEDIATION
			added client-auth EKU, relaxed approval) and restore the intended secure configuration.
14	**Local Administrator Access (AdminTo)** `T1021.002 · Remote Services: SMB/Windows Admin Shares`	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	MEDIUM Remove local administrator rights from non-privileged accounts on target machines. Deploy LAPS for local admin password management. Implement tiered access model (PAWs for admin tasks). • Enumerate the effective local administrators on the host and remove every principal that does not require them: Invoke-Command -ComputerName braavos.essos.local -ScriptBlock { Get-LocalGroupMember -Group 'Administrators' }. • Replace broad, GPO-pushed 'all workstation admins' groups with narrowly-scoped, per-tier groups so a single group cannot make one account admin on hundreds of machines; audit the nesting with Get-ADGroupMember -Recursive. • Deploy LAPS so each host has a unique, rotated local Administrator password, removing the shared-local-admin lateral-movement path.
15	**Certificate Enrollment Relay (ADCS ESC8)** `T1649 · Steal or Forge Authentication Certificates`	Would eliminate 1 of 17 mapped attack paths ADscan has not yet executed.	HIGH Enforce HTTPS on all CA web enrollment endpoints. Enable Extended Protection for Authentication (EPA) on IIS. Disable HTTP enrollment. May require IIS and CA reconfiguration. • Enforce SMB signing and, where possible, disable NTLM in favour of Kerberos so the coercion-to-relay chain has no authentication to capture. • Enforce LDAP signing and channel binding on domain controllers so a coerced authentication cannot be relayed to the directory either. • Reduce which accounts can be coerced by hardening the coercion triggers (Print Spooler, EFSRPC, DFS) on domain controllers and servers.

08 Remediation Roadmap

Prioritised action plan to reduce risk across the environment.

Work the fixes in the order set by Section 07 (Start Here), which ranks them by proven execution first and then by how many attack paths each one breaks. The windows below group those same fixes by remediation horizon; within each window they follow that Start Here order, not raw severity.

> **Start here.** The 3 containment actions below are not findings and do not appear on the timeline. They exist because the assessment succeeded: material that authenticates against your directory is now outside your control, and only your team can take it back. Complete them first. Nothing else on this roadmap is effective while they are outstanding.

CONTAINMENT 1 OF 3

Reset the krbtgt password twice, with replication in between

This assessment recovered the krbtgt account's key material in essos.local. That key signs every Kerberos ticket the domain issues, so anyone holding it can mint a ticket for any account, including accounts that do not exist, and every domain controller will accept it.

Reset it twice. A domain controller keeps the previous krbtgt key and keeps honouring tickets signed with it, which is deliberate: it stops a single reset from cutting off every session in the domain at once. It also means one reset leaves forged tickets working. The second reset is what removes the old key from circulation, and it only works if the first one has replicated everywhere before you run it.

1. Reset the password once. The value you type is discarded and the domain replaces it with a random key, so any long random string will do.

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (Read-Host -AsSecureString 'New krbtgt password')
```

2. Confirm the reset has reached every domain controller before you go further. Every controller must report the same new pwdLastSet.

```
repadmin /replsummary
```

```
Get-ADDomainController -Filter * | ForEach-Object { Get-ADUser krbtgt -Server $_.HostName -Properties pwdLastSet | Select-Object
@{n='DC';e={$_.PSComputerName}}, @{n='pwdLastSet';e={[datetime]::FromFileTime($_.pwdLastSet)}} }
```

3. Wait out the maximum ticket lifetime, ten hours under the default Kerberos policy, so tickets issued under the old key have expired on their own. Resetting twice inside that window forces every session in the domain to re-authenticate at once, which is what turns a contained incident into an outage.

4. Reset the password a second time, exactly as in step 1.

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (Read-Host -AsSecureString 'New krbtgt password')
```

5. If the forest holds read-only domain controllers, each one has its own krbtgt account (krbtgt_<number>). Reset those on the same schedule; they are separate keys and the two resets above do not touch them.

```
Get-ADUser -LDAPFilter '(samAccountName=krbtgt_*)' -Properties pwdLastSet
```

WHAT STAYS TRUE AFTERWARDS

Tickets already issued stay valid until they expire, so plan the two resets alongside the credential rotation below rather than treating either as an instant cut-off.

CONTAINMENT 2 OF 3

Treat every recovered credential as compromised and rotate it

The assessment recovered credential material for 9 accounts in essos.local: administrator, daenerys.targaryen, drogon, jorah.mormont, khal.drogo, missandei, sql_svc, vagrant, viserys.targaryen. Each is compromised, whatever was recovered for it: a password hash and a Kerberos key authenticate as the account just as a password does. A full replication of the directory database also completed in essos.local, which means every account's password hash in that domain was exposed, not only the accounts named above. Treat the list as the confirmed minimum.

How each account was reached is a separate question from what to do about it. Closing the route stops the next attacker; it does nothing about the credential itself, which is already outside your control and has to be replaced.

1. Reset the password on every account named above. Disabling, renaming or moving an account does not help: the recovered material is derived from the password, so only a password change invalidates it.

```
Set-ADAccountPassword -Identity <account> -Reset -NewPassword (Read-Host -AsSecureString 'New password')
```

```
Set-ADUser -Identity <account> -ChangePasswordAtLogon $true
```

2. Handle the service accounts first and separately. An account with a registered service principal name is running something, and resetting it without updating wherever that service stores the password takes the service down. Find them, schedule the change, update the service configuration and the reset together.

```
Get-ADUser -LDAPFilter '(servicePrincipalName=*)' -Properties servicePrincipalName, PasswordLastSet | Select-Object SamAccountName, PasswordLastSet, servicePrincipalName
```

3. Where a service account can move to a group managed service account, move it. The directory then rotates the password on its own every thirty days and this class of exposure stops recurring.

```
New-ADServiceAccount -Name <gmsa-name> -DNSHostName <service-host-fqdn> -PrincipalsAllowedToRetrieveManagedPassword '<HOST$>'
```

```
Install-ADServiceAccount -Identity <gmsa-name>
```

4. Check whether any of these passwords is in use anywhere else: a local administrator account, a scheduled task, an application configuration file, a second directory. A recovered password is compromised everywhere it was ever used, not only where it was found.

WHAT STAYS TRUE AFTERWARDS

Rotate in order of privilege, not alphabetically: an account that can reach a domain controller matters more than one that cannot, and a partial rotation that leaves the privileged accounts for last leaves the compromise intact.

CONTAINMENT 3 OF 3

Revoke the certificate your CA issued during the assessment

Your certification authority issued 2 certificates during this assessment, authenticating as administrator@essos.local, valid until 2027-08-02 09:58 UTC. A certificate outlives the engagement by design: it keeps authenticating until it expires or is revoked, and nothing in the directory takes it out of service.

Revoking needs certificate-manager rights on the issuing CA, which this assessment did not hold, so it is the one action only your team can complete.

1. Revoke each certificate on the issuing CA, as a member of its Certificate Managers group: locate the record by request ID, revoke it with reason code 1 (key compromise) because the private key was generated outside your control, publish a fresh revocation list, then confirm the record's disposition reads 21.
2. Close the template that allowed the certificate to be requested with someone else's identity. Revoking one certificate without fixing the template means the next request succeeds the same way.

Section 09 carries the request ID, the serial number and the exact command sequence for each one.

WHAT STAYS TRUE AFTERWARDS

Revocation only stops future authentication. A Kerberos ticket already obtained with the certificate stays valid for its lifetime, and if the certificate carried a privileged identity, that account's password has to be reset once the revocation is confirmed.

IMMEDIATE · 0-30 DAYS

Contain critical exposure

Complete the 3 containment actions above first, then work through the findings below.

- **ADCS ESC1 - Misconfigured Certificate Template** · essos.local · ADscan Priority 9.9
- **ADCS ESC5 - Vulnerable CA Object ACL** · essos.local · ADscan Priority 9.0
- **ADCS ESC9 - No Security Extension on Certificate Template** · essos.local · ADscan Priority 9.0
- **LAPS Password Readable by Non-Admins** · essos.local · ADscan Priority 8.8
- **ADCS ESC2 - Any Purpose Certificate Template** · essos.local · ADscan Priority 9.0
- **ADCS ESC3 - Enrollment Agent Template Abuse** · essos.local · ADscan Priority 9.0
- **ADCS ESC4 - Vulnerable Certificate Template ACL** · essos.local · ADscan Priority 9.0
- **ADCS ESC8 - NTLM Relay to Web Enrollment** · essos.local · ADscan Priority 9.0
- **Attack Path: Domain Users → essos.local** · essos.local · ADscan Priority 9.8
- **noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)** · essos.local · ADscan Priority 9.8
- **ADCS ESC14 - Weak Explicit Certificate Mapping Abuse** · essos.local · ADscan Priority 9.0
- **ADCS ESC7 - Certificate Authority Privilege Abuse** · essos.local · ADscan Priority 9.0
- **PrintNightmare Vulnerable Hosts Detected** · essos.local · ADscan Priority 8.8
- **Domain Controller Accepts NTLMv1 Authentication** · essos.local · ADscan Priority 8.5
- **gMSA Password Readable by Non-Admins** · essos.local · ADscan Priority 7.5
- **SMBv1 Protocol Enabled** · essos.local · ADscan Priority 7.5

SHORT-TERM · 30-90 DAYS

Reduce attack surface

- **AS-REP Roasting** · essos.local · ADscan Priority 6.9
- **Kerberoasting** · essos.local · ADscan Priority 5.3
- **Weak Default Domain Password Policy** · essos.local · ADscan Priority 5.3
- **SMB Signing Not Required** · essos.local · ADscan Priority 5.0

LONG-TERM · 90+ DAYS

Harden baseline

- **Accounts with Non-Expiring Passwords** · essos.local
- **Machine Account Quota Allows Domain Join** · essos.local
- **Passwords Predating Current Policy** · essos.local

SECTION 09

09 Environment Modifications & Cleanup

A complete record of the changes this assessment made to the directory and the state each was left in.

Testing some attack paths requires changing live directory objects. Each change below was logged as it was made. Where a change could be undone, the assessment reverted it and then re-read the object to confirm the change was gone. Any change that could not be confirmed as reverted is listed under **Requires manual cleanup** with the exact object and the command to run.

0
REVERTED & CONFIRMED

2
REQUIRES MANUAL CLEANUP

Changes the assessment made and reverted

The assessment created these changes and then confirmed, by re-reading the object, that each was removed. No further action is needed for the items below.

No changes were automatically reverted during this assessment.

Requires manual cleanup

The assessment could not confirm these changes were reverted. Complete the actions below before closing the engagement. Each entry names the affected object and carries the native procedure that restores it, ready to run.

1 **Certificate issued by your CA** No automatic rollback is possible

`CA ESSOS-CA on braavos.essos.local · Request ID 16`

THE PROCEDURE, WITH THIS ENGAGEMENT'S VALUES

```
Certificate authenticates as administrator@essos.local, issued from template ESC1, by ESSOS-CA, valid until 2027-08-02 09:45 UTC.
Your certification authority issued this certificate during the assessment. It stays valid for authentication until it expires or is
     revoked, and revoking it requires certificate-manager rights on the CA, so your team has to complete this step.
Run the commands below on the CA server, or on any host with the Certification Authority tools installed, as a member of the CA's
     Certificate Managers group (or the CA host's local Administrators):
  1. Locate the record and confirm it is still live
     certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "RequestId=16" -out
     "RequestId,Request.RequesterName,Certificate.SerialNumber,Certificate.NotAfter,Request.Disposition"
     A Disposition of 20 means the certificate is issued and usable.
  2. Revoke it. Reason code 1 is key compromise, which is the accurate reason here: the private key was generated outside your control.
     certutil -config "braavos.essos.local\ESSOS-CA" -revoke 33000000105351CB9FFED76161000000000010 1
  3. Publish a fresh CRL so domain members learn of the revocation
     certutil -config "braavos.essos.local\ESSOS-CA" -CRL
  4. Verify the change took effect
     certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "SerialNumber=33000000105351CB9FFED76161000000000010" -out
     "Request.Disposition,Request.RevokedReason"
     Disposition must now read 21 (revoked).
Two caveats worth planning for. The certificate keeps working until the new CRL has replicated to every CRL distribution point published in
     it, so confirm distribution with certutil -verify -urlfetch against a copy of the certificate. And revocation only stops future
     authentication: any Kerberos ticket already obtained with the certificate remains valid until it expires under Default Domain Policy >
     Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Kerberos Policy. If the certificate
     carried the identity of a privileged or machine account, reset that account's password once the revocation is confirmed.
```

2 **Certificate issued by your CA** No automatic rollback is possible

CA ESSOS-CA on braavos.essos.local · Request ID 17

THE PROCEDURE, WITH THIS ENGAGEMENT'S VALUES

```
Certificate authenticates as administrator@essos.local, issued from template ESC1, by ESSOS-CA, valid until 2027-08-02 09:58 UTC.
Your certification authority issued this certificate during the assessment. It stays valid for authentication until it expires or is
     revoked, and revoking it requires certificate-manager rights on the CA, so your team has to complete this step.
Run the commands below on the CA server, or on any host with the Certification Authority tools installed, as a member of the CA's
     Certificate Managers group (or the CA host's local Administrators):
  1. Locate the record and confirm it is still live
     certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "RequestId=17" -out
     "RequestId,Request.RequesterName,Certificate.SerialNumber,Certificate.NotAfter,Request.Disposition"
     A Disposition of 20 means the certificate is issued and usable.
  2. Revoke it. Reason code 1 is key compromise, which is the accurate reason here: the private key was generated outside your control.
     certutil -config "braavos.essos.local\ESSOS-CA" -revoke 3300000011FB687872BA4896D0000000000011 1
  3. Publish a fresh CRL so domain members learn of the revocation
     certutil -config "braavos.essos.local\ESSOS-CA" -CRL
  4. Verify the change took effect
     certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "SerialNumber=3300000011FB687872BA4896D0000000000011" -out
     "Request.Disposition,Request.RevokedReason"
     Disposition must now read 21 (revoked).
Two caveats worth planning for. The certificate keeps working until the new CRL has replicated to every CRL distribution point published in
     it, so confirm distribution with certutil -verify -urlfetch against a copy of the certificate. And revocation only stops future
     authentication: any Kerberos ticket already obtained with the certificate remains valid until it expires under Default Domain Policy >
     Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Kerberos Policy. If the certificate
     carried the identity of a privileged or machine account, reset that account's password once the revocation is confirmed.
```